FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

MK FRAUD INSIGHTS

COMPREHENSIVE FRAUD READINESS REPORT

# Fraud exposure, target control environment and implementation programme

**55.10**
READINESS / 100

**DEVELOPING**
MATURITY BAND

PREPARED FOR

## Fictional Retail Group (extensive unanswered information)

Assessment reference · FX-P5

CONFIDENTIAL · AUTOMATED ANALYSIS · NOT INDEPENDENTLY REVIEWED

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# Contents


**Management report** — SECTIONS 1–9

1 · Where the organisation stands

2 · What is driving the position

3 · Where the material fraud exposure sits

4 · Fraud scenario portfolio

5 · The control environment management should build

6 · Who must own the response

7 · Decisions leadership must make

8 · What should happen, and in what order

9 · How management will know it is working

**Analytical registers** — APPENDICES A–F

| | |
|---|---|
| A · Finding register | 59 entries |
| B · Fraud risk register | 59 entries |
| C · Control blueprint register | 59 entries |
| D · Evidence requirement register | 45 entries |
| E · 12-month action and assurance register | 142 entries |
| F · Measurement register | 59 entries |


**THE TWO HALVES OF THIS REPORT**

Sections 1–9 are the management report: what the assessment shows, what it means, and what to do about it. Appendices A–F are the analytical registers behind those sections. They contain every finding, risk, control design, evidence requirement, action and measure, with the identifiers that connect them. The management sections state nothing the registers do not hold.

**BASIS OF THIS REPORT**

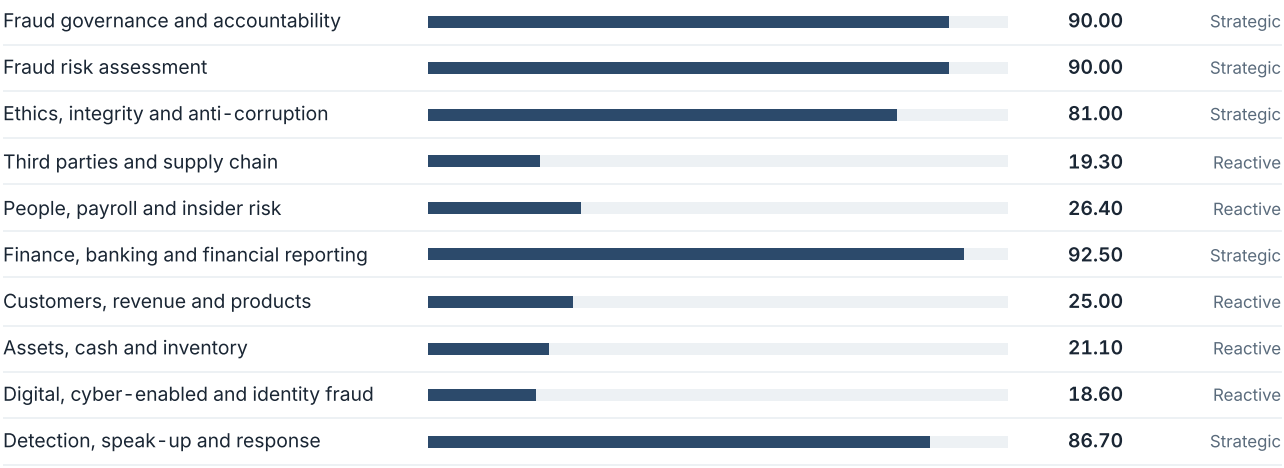
This report is produced by automated analysis of the recorded MK Fraud Readiness assessment. It has not been independently reviewed. No evidence has been examined, no control has been tested for operating effectiveness, no personnel have been interviewed, and no assurance opinion is given. Assessment positions are self-reported by the organisation. Recommended control designs, evidence requirements and operating measures are MK methodology: what good practice requires, not observations of what the organisation currently does.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# The assessed readiness position

| 55.10 | Developing | 10 | 59 | 59 |
|---|---|---|---|---|
| READINESS SCORE OUT OF 100 | MATURITY BAND | DOMAINS ASSESSED | MATERIAL FINDINGS | CONTROL DESIGNS RECOMMENDED |

## Domain readiness profile



| | | |
|---|---|---|
| Fraud governance and accountability | 90.00 | Strategic |
| Fraud risk assessment | 90.00 | Strategic |
| Ethics, integrity and anti-corruption | 81.00 | Strategic |
| Third parties and supply chain | 19.30 | Reactive |
| People, payroll and insider risk | 26.40 | Reactive |
| Finance, banking and financial reporting | 92.50 | Strategic |
| Customers, revenue and products | 25.00 | Reactive |
| Assets, cash and inventory | 21.10 | Reactive |
| Digital, cyber-enabled and identity fraud | 18.60 | Reactive |
| Detection, speak-up and response | 86.70 | Strategic |

Ordered as assessed. Positions are self-reported through the assessment and have not been independently verified.

**EXECUTIVE INTERPRETATION**

Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# The patterns beneath the score

The assessment produced 59 material findings. They resolve into 8 connected patterns, ordered by how much of the organisation's critical control population each one affects.

| PATTERN | FINDINGS | CRITICAL | HARD GATE | MANAGEMENT QUESTION THIS RAISES |
|---|---|---|---|---|
| **Supplier and payment integrity**<br>Third parties and supply chain · Customers, revenue and products · Ethics, integrity and anti-corruption | 15 | 6 | Not recorded | Can value be redirected before anyone independently challenges it? |
| **Identity and access challenge**<br>Digital, cyber-enabled and identity fraud · Customers, revenue and products · People, payroll and insider risk | 14 | 5 | Not recorded | Is authority verified at the points where it can be misused? |
| **Payroll integrity**<br>People, payroll and insider risk | 10 | 5 | Not recorded | Could pay be redirected, inflated or paid to someone who does not work here? |
| **Detection and exception review**<br>Customers, revenue and products | 8 | 3 | Not recorded | Would unusual activity be seen and challenged in time? |
| **Stock and asset custody**<br>Assets, cash and inventory | 8 | 1 | Not recorded | Could stock or assets leave, or be written off, without a record that someone checks? |
| **Incident response and evidence integrity**<br>Digital, cyber-enabled and identity fraud | 2 | 1 | Not recorded | When something is suspected, can we contain it and keep the evidence? |
| **Cash custody**<br>Assets, cash and inventory | 1 | 1 | Not recorded | Could cash be taken before or after it is recorded without anyone noticing? |
| **Culture and continuous improvement**<br>Ethics, integrity and anti-corruption | 1 | Not recorded | Not recorded | Do people recognise fraud, and does the control environment learn? |

Every finding behind these patterns is listed in Appendix A.

> **WHY THIS MATTERS**
>
> Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# Exposure by control family

59 fraud risks arise from the assessed position. They concentrate in 8 exposure families.

| EXPOSURE FAMILY | RISKS | DOMAINS AFFECTED | WHAT THE ORGANISATION IS EXPOSED TO |
|---|---|---|---|
| **Supplier and payment integrity** | 15 | Ethics, integrity and anti-corruption · Third parties and supply chain | Can value be redirected before anyone independently challenges it? |
| **Identity and access challenge** | 14 | People, payroll and insider risk · Customers, revenue and products | Is authority verified at the points where it can be misused? |
| **Payroll integrity** | 10 | People, payroll and insider risk | Could pay be redirected, inflated or paid to someone who does not work here? |
| **Detection and exception review** | 8 | Customers, revenue and products | Would unusual activity be seen and challenged in time? |
| **Stock and asset custody** | 8 | Assets, cash and inventory | Could stock or assets leave, or be written off, without a record that someone checks? |
| **Incident response and evidence integrity** | 2 | Digital, cyber-enabled and identity fraud | When something is suspected, can we contain it and keep the evidence? |
| **Culture and continuous improvement** | 1 | Ethics, integrity and anti-corruption | Do people recognise fraud, and does the control environment learn? |
| **Cash custody** | 1 | Assets, cash and inventory | Could cash be taken before or after it is recorded without anyone noticing? |

Full risk statements, causes and treatment directions are in Appendix B. Risks are derived from assessed control positions; no likelihood or monetary value is assigned, because the assessment does not support one.

**MANAGEMENT IMPLICATION**

Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# Fraud scenario portfolio

Conditional pathways derived from the recorded control position. Each shows how it could begin, how it could progress, the control response that would interrupt it, and what management could observe first. No allegation that any event has occurred.

| PATHWAY | HOW IT COULD BEGIN | HOW IT COULD PROGRESS | INTERRUPTION POINT | WARNING INDICATORS | LINKS |
|---|---|---|---|---|---|
| Invoices are paid for goods or services not received or not agreed<br>SUPPLIER PAYMENT DIVERSION | Overbilling, fictitious deliveries or inflated rates are paid. | Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid. What the answers show: Invoices are paid without being checked against what was approved or received. Quantities checked: not in place. Services confirmed: not in place. | Every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first. Quantities checked: the answer to "Are delivered quantities checked against the delivery note and the order?" is yes, across everything it should cover. Services confirmed: the answer to "For services, does the person receiving the service confirm it was delivered before payment?" is yes, across everything it should cover. Every purchase is approved by someone with the authority to do so before the organisation commits, and the approval is recorded. Receipt is always recorded before the related invoice is paid. | • Unauthorised commitments and approval override<br>• Duplicate or false invoices<br>• Overpricing, overbilling and inflated variations<br>• Goods or services paid for but not received<br>• Counterfeit, substituted or substandard goods<br>• Misrepresented supplier credentials | RISK-FS-D4-05, CI-FS-D4-05 |
| Supplier payments are diverted through changed bank details<br>SUPPLIER PAYMENT DIVERSION | A fraudster, often impersonating the supplier by email, voice or video, has the bank account changed. | Changed supplier bank details are the most common route for payment fraud, and cloned voices now defeat call-backs that rely on recognition. What the answers show: A follow-up call from the 'supplier' is accepted as confirmation. Changes are confirmed, but sometimes using contact details taken from the request itself. | The procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why. Every change is confirmed with the supplier using contact details already on file before it takes effect. | • Payment redirection through false bank details or impersonation | RISK-FS-D4-02, CI-FS-D4-02 |
| Salaries are redirected through a fake bank change<br>PAYROLL MANIPULATION | A request that appears to come from an employee changes where their salary is paid. | Salary redirection through fake bank change requests is common and fast. What the answers show: Bank detail changes are made as requested. | Every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect. | • Salary redirection through changed bank details<br>• Ghost or fictitious employees and payees<br>• Unauthorised pay increases, allowances or deductions | RISK-FS-D5-01, CI-FS-D5-01 |
| A payment instruction received by email is acted on<br>IDENTITY IMPERSONATION | Changed details or urgent payments are processed on the strength of an email. | Acting on payment instructions received by email is how business email compromise succeeds. What the answers show: Payment changes received by email are acted on as received. | An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it. | • Business email compromise and payment redirection<br>• Takeover of staff accounts | RISK-FS-D9-02, CI-FS-D9-02 |

| PATHWAY | HOW IT COULD BEGIN | PROGRESS | INTERRUPTION POINT | INDICATORS | LINKS |
|---|---|---|---|---|---|
| One person can order and approve payment<br>SUPPLIER PAYMENT DIVERSION | A buyer invents or inflates a purchase and approves its payment. | One person who can both order and approve payment can pay a supplier they invented. What the answers show: The same person can order and approve payment. | The duties are always separated, or any exception is approved and recorded. | • Unauthorised commitments and approval override<br>• Irregular deviations and emergency purchases<br>• Kickbacks and bribery<br>• Goods or services paid for but not received<br>• Duplicate or false invoices | RISK-FS-D4-04, CI-FS-D4-04 |
| An email account is taken over<br>IDENTITY IMPERSONATION | A mailbox without strong sign-in is used to send or intercept payment instructions. | Most business email compromise starts with an account that has no multi-factor authentication. What the answers show: Email accounts are protected by passwords only. | Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. | • Takeover of staff accounts<br>• Business email compromise and payment redirection<br>• Spoofed or lookalike email in the organisation's name<br>• Criminals impersonating the organisation to customers, suppliers and the public<br>• Slow response that lets losses grow | RISK-FS-D9-01, CI-FS-D9-01 |
| A fictitious supplier is created and paid<br>SUPPLIER PAYMENT DIVERSION | An insider or outsider adds a supplier that does not exist and invoices it. | Fictitious suppliers enter through onboarding that can be skipped. What the answers show: Checks happen only when someone thinks to do them. Directors compared with staff: not in place. Dormant suppliers deactivated: not in place. | Every new supplier goes through a defined process, with set checks and an approval, before it can be paid. Directors compared with staff: the answer to "Do you compare supplier directors, owners, addresses or bank accounts with your employee records?" is yes, across everything it should cover. Dormant suppliers deactivated: the answer to "Are suppliers that have not been used for a set period deactivated?" is yes, across everything it should cover. Suppliers re-checked: the answer to "Are existing suppliers re-checked periodically, not only when they are first added?" is yes, across everything it should cover. Directors and owners, including those behind holding companies, are identified for every new supplier from an independent source. | • Fictitious or shell suppliers<br>• Undisclosed conflicts of interest<br>• Misrepresented supplier credentials<br>• Duplicate or false invoices | RISK-FS-D4-01, CI-FS-D4-01 |
| Buyers take kickbacks<br>THIRD PARTY COLLUSION | A long-standing buyer-supplier relationship hides favours. | What the answers show: Buying staff do not declare interests. | Everyone involved in buying declares interests each year and when circumstances change, and declarations are kept on record. | • Undisclosed conflicts of interest<br>• Kickbacks and bribery<br>• Bid rigging and collusion | RISK-FS-D4-09, CI-FS-D4-09 |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

| PATHWAY | HOW IT COULD BEGIN | PROGRESS | INTERRUPTION POINT | INDICATORS | LINKS |
|---|---|---|---|---|---|
| Refunds are stolen<br>DETECTION EVASION | One person raises and approves refunds or credit notes to themselves or accomplices. | Refunds processed and approved by one person are a classic way to steal. What the answers show: Approval is sought only for large refunds or when staff are unsure. Returns received before credit: not in place. Claim evidence checked for AI: not in place. | Every refund and credit note is approved by someone other than the person who processes it. Returns received before credit: the answer to "Is every return matched to the goods physically coming back into stock before a credit is issued?" is yes, across everything it should cover. Claim evidence checked for AI: the answer to "Are photographs and documents supporting refund or return requests checked for manipulation, such as AI-generated images of damage?" is yes, across everything it should cover. Refund patterns reviewed: the answer to "Are refunds and credit notes reviewed for patterns, such as the same employee or customer, or amounts just below approval limits?" is yes, across everything it should cover. Post-period reversals reviewed: the answer to "Are credit notes and reversals raised after a period end reviewed, so sales reversed once targets were met are noticed?" is yes, across everything it should cover. | • False refunds, credit notes and returns<br>• Stolen or diverted customer payments, including lapping<br>• Fictitious sales and commission fraud | RISK-FS-D7-01, CI-FS-D7-01 |

| PATHWAY | HOW IT COULD BEGIN | PROGRESS | INTERRUPTION POINT | INDICATORS | LINKS |
|---|---|---|---|---|---|
| Credit is obtained with fabricated documents<br>DETECTION EVASION | Fake payslips and bank statements, now easy to generate, secure credit that is never repaid. | Application fraud with fabricated documents drives credit losses. What the answers show: Documents are checked only if something looks wrong. Statements sent from the system: not in place. Limit and terms changes approved: set out but not yet working in practice. | The key information in every application is verified with the source, such as the employer, the bank or a verification service, before credit is approved. Statements sent from the system: the answer to "Are customer statements sent directly from the system, so that an employee cannot hide a diverted payment from the customer?" is yes, across everything it should cover. Limit and terms changes approved: the answer to "Are changes to credit limits and payment terms approved and logged?" is yes, across everything it should cover. Every credit limit is approved by someone other than the salesperson, within set authority levels. Bureau and fraud database checks: the answer to "Are applicants checked with a credit bureau and a fraud database, such as the Southern African Fraud Prevention Service, before credit is approved?" is yes, across everything it should cover. | • Application and credit fraud using forged documents<br>• Unauthorised discounts, price overrides and side agreements<br>• Customers using false or stolen identities<br>• Stolen or diverted customer payments, including lapping | RISK-FS-D7-03, CI-FS-D7-03 |
| Fuel and fleet are misused<br>STOCK ASSET MISUSE | Fuel cards or vehicles are used privately or fraudulently. | What the answers show: Fuel purchases are not compared with vehicle use. | Every vehicle's fuel purchases are compared with tracking data, distance travelled and expected consumption, and exceptions are investigated. | • Fuel card fraud and vehicle misuse<br>• Short deliveries and theft in transit<br>• Fake proof of payment, deposit or delivery<br>• Inflated maintenance and parts fraud<br>• Organised theft of high-value materials | RISK-FS-D8-07, CI-FS-D8-07 |
| A cloned voice or video instruction is obeyed<br>IDENTITY IMPERSONATION | A caller who sounds or looks like a known person is believed. | Voices and faces can be cloned, so only an agreed verification method holds. What the answers show: Some staff check unusual requests, depending on their own judgement. Most changes are verified through the old details or another trusted route. Most executives with a public profile have agreed a verification method with their assistants and finance teams. | An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it. Every change to a phone number or email used for verification is confirmed through the previous details or another trusted route before it is used. Every executive with a public voice or face has been briefed and has an agreed verification method that their assistants and finance teams use. | • Deepfake voice and video impersonation of executives and staff<br>• Business email compromise and payment redirection<br>• Takeover of staff accounts<br>• SIM swaps and intercepted one-time PINs | RISK-FS-D9-03, CI-FS-D9-03 |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# The control programmes

The 59 recommended control designs group into 8 programmes. Each is one coherent piece of work with one accountable executive.

| PROGRAMME | CONTROLS | EVIDENCE | MEASURES | ACCOUNTABLE | HORIZON |
|---|---|---|---|---|---|
| **Supplier and payment integrity** | 15 | 13 | 15 | Head of procurement | 90 days, 60 days, 30 days |
| **Identity and access challenge** | 14 | 13 | 14 | Head of IT | 90 days, 60 days, 30 days |
| **Payroll integrity** | 10 | 6 | 10 | HR | 30 days, 60 days, 90 days |
| **Detection and exception review** | 8 | 6 | 8 | Commercial | 60 days, 90 days |
| **Stock and asset custody** | 8 | 4 | 8 | Operations | 60 days, 90 days |
| **Incident response and evidence integrity** | 2 | 2 | 2 | Head of IT | 60 days, 90 days |
| **Culture and continuous improvement** | 1 | 0 | 1 | People, learning and ethics | 90 days |
| **Cash custody** | 1 | 1 | 1 | Operations | 60 days |

Individual control designs are in Appendix C; the evidence each requires is in Appendix D.

> **CONTROL PROGRAMME SYNTHESIS**
>
> Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# Programme detail

## Supplier and payment integrity

15 CONTROLS

*Can value be redirected before anyone independently challenges it?*

**Accountable**: Head of procurement
**Delivery horizon**: 90 days, 60 days, 30 days
**Evidence expected** · 13 items across 9 controls
**Effectiveness measures** · 15

Controls: CI-FS-D3-11, CI-FS-D4-01, CI-FS-D4-02, CI-FS-D4-03, CI-FS-D4-04, CI-FS-D4-05, CI-FS-D4-06, CI-FS-D4-07, CI-FS-D4-08, CI-FS-D4-09, CI-FS-D4-10, CI-FS-D4-11, CI-FS-D4-12, CI-FS-D4-13, CI-FS-D7-12

## Identity and access challenge

14 CONTROLS

*Is authority verified at the points where it can be misused?*

**Accountable**: Head of IT
**Delivery horizon**: 90 days, 60 days, 30 days
**Evidence expected** · 13 items across 10 controls
**Effectiveness measures** · 14

Controls: CI-FS-D5-12, CI-FS-D7-02, CI-FS-D9-01, CI-FS-D9-02, CI-FS-D9-03, CI-FS-D9-04, CI-FS-D9-06, CI-FS-D9-07, CI-FS-D9-08, CI-FS-D9-09, CI-FS-D9-10, CI-FS-D9-11, CI-FS-D9-13, CI-FS-D9-14

## Payroll integrity

10 CONTROLS

*Could pay be redirected, inflated or paid to someone who does not work here?*

**Accountable**: HR
**Delivery horizon**: 30 days, 60 days, 90 days
**Evidence expected** · 6 items across 5 controls
**Effectiveness measures** · 10

Controls: CI-FS-D5-01, CI-FS-D5-02, CI-FS-D5-03, CI-FS-D5-04, CI-FS-D5-05, CI-FS-D5-07, CI-FS-D5-08, CI-FS-D5-09, CI-FS-D5-10, CI-FS-D5-11

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# Programme detail

## Detection and exception review

8 CONTROLS

*Would unusual activity be seen and challenged in time?*

**Accountable**: Commercial
**Delivery horizon**: 60 days, 90 days
**Evidence expected** · 6 items across 5 controls
**Effectiveness measures** · 8

Controls: CI-FS-D7-01, CI-FS-D7-03, CI-FS-D7-05, CI-FS-D7-09, CI-FS-D7-10, CI-FS-D7-11, CI-FS-D7-13, CI-FS-D7-14

## Stock and asset custody

8 CONTROLS

*Could stock or assets leave, or be written off, without a record that someone checks?*

**Accountable**: Operations
**Delivery horizon**: 60 days, 90 days
**Evidence expected** · 4 items across 3 controls
**Effectiveness measures** · 8

Controls: CI-FS-D8-02, CI-FS-D8-04, CI-FS-D8-05, CI-FS-D8-06, CI-FS-D8-07, CI-FS-D8-08, CI-FS-D8-09, CI-FS-D8-11

## Incident response and evidence integrity

2 CONTROLS

*When something is suspected, can we contain it and keep the evidence?*

**Accountable**: Head of IT
**Delivery horizon**: 60 days, 90 days
**Evidence expected** · 2 items across 2 controls
**Effectiveness measures** · 2

Controls: CI-FS-D9-05, CI-FS-D9-12

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# Programme detail

## Culture and continuous improvement

1 CONTROLS

*Do people recognise fraud, and does the control environment learn?*

**Accountable**: People, learning and ethics
**Evidence expected** · 0 items across 0 controls
**Delivery horizon**: 90 days
**Effectiveness measures** · 1

Controls: CI-FS-D3-10

## Cash custody

1 CONTROLS

*Could cash be taken before or after it is recorded without anyone noticing?*

**Accountable**: Operations
**Evidence expected** · 1 items across 1 controls
**Delivery horizon**: 60 days
**Effectiveness measures** · 1

Controls: CI-FS-D8-01

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# The governance model

Accountability is expressed as roles, not individuals. The assessment does not identify people, and this report does not infer them.

| ROLE | STANDING | CONTROLS | DECISIONS | EVIDENCE | ESCALATION RESPONSIBILITY |
|---|---|---|---|---|---|
| **Head of IT** | executive accountability | 14 | Not recorded | 7 | Not recorded |
| **Head of procurement** | executive accountability | 13 | 2 | 3 | Not recorded |
| **HR** | executive accountability | 11 | Not recorded | 3 | Not recorded |
| **Commercial** | executive accountability | 10 | Not recorded | Not recorded | Not recorded |
| **Operations** | executive accountability | 9 | Not recorded | Not recorded | Not recorded |
| **Chief Financial Officer** | executive accountability | 2 | Not recorded | 3 | Not recorded |
| **Chief Executive / Managing Director** | executive accountability | Not recorded | 3 | Not recorded | Not recorded |
| **Financial controller** | process ownership | 6 | Not recorded | 3 | Not recorded |
| **Creditors manager** | process ownership | 4 | Not recorded | 4 | Not recorded |
| **Procurement and vendor management** | process ownership | 3 | Not recorded | 4 | Not recorded |
| **Payroll manager** | process ownership | 3 | Not recorded | 2 | Not recorded |
| **People, learning and ethics** | process ownership | 2 | 1 | Not recorded | Not recorded |
| **HR manager** | process ownership | 2 | Not recorded | 3 | Not recorded |
| **Billing** | process ownership | 2 | Not recorded | 2 | Not recorded |
| **HR lead** | process ownership | 1 | Not recorded | Not recorded | Not recorded |
| **CSI** | process ownership | 1 | Not recorded | Not recorded | Not recorded |
| **Operations manager** | process ownership | 1 | Not recorded | Not recorded | Not recorded |
| **Customer service** | process ownership | 1 | Not recorded | 1 | Not recorded |
| **Customer onboarding** | process ownership | 1 | Not recorded | 1 | Not recorded |
| **Credit manager** | process ownership | 1 | Not recorded | 2 | Not recorded |
| **Claims manager** | process ownership | 1 | Not recorded | 1 | Not recorded |
| **Sales** | process ownership | 1 | Not recorded | Not recorded | Not recorded |
| **Channel** | process ownership | 1 | Not recorded | Not recorded | Not recorded |
| **Marketing manager** | process ownership | 1 | Not recorded | Not recorded | Not recorded |
| **Fraud** | process ownership | 1 | Not recorded | Not recorded | Not recorded |
| **Store, branch** | process ownership | 1 | Not recorded | 1 | Not recorded |
| **Asset** | process ownership | 1 | Not recorded | Not recorded | Not recorded |
| **Warehouse** | process ownership | 1 | Not recorded | Not recorded | Not recorded |
| **Fleet manager** | process ownership | 1 | Not recorded | 1 | Not recorded |
| **Logistics manager** | process ownership | 1 | Not recorded | Not recorded | Not recorded |
| **Security manager** | process ownership | 1 | Not recorded | Not recorded | Not recorded |
| **Head of digital channels** | process ownership | 1 | Not recorded | 1 | Not recorded |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# The decision agenda

| DECISION | WHY NOW | RECOMMENDED DIRECTION | OWNER | CONSEQUENCE OF DELAY |
|---|---|---|---|---|
| **Name one accountable executive for each area with first-priority schemes open or unsupported: procurement and third parties (6), people and payroll (5), digital and identity (5), customers and revenue (4) and cash, stock and assets (2).** | Each scheme needs one person with authority over the process, the system and the people involved. | Head of procurement or CFO for procurement and third parties, HR or payroll manager for people and payroll, Head of IT or IT provider for digital and identity and Commercial or finance manager for customers and revenue. | Chief Executive / Managing Director<br>30 days | Schemes with no owner stay open, and the gaps that let them happen stay unassigned. |
| **Approve the target design for procurement and third parties, where 6 first-priority schemes are open or unsupported.** | The schemes share processes and owners; designing them together avoids separate partial fixes. | Every new supplier goes through a defined process, with set checks and an approval, before it can be paid. Directors compared with staff: the answer to "Do you compare supplier directors, owners, addresses or bank accounts with your employee records?" is yes, across everything it should cover. Dormant suppliers deactivated: the answer to "Are suppliers that have not been used for a set period deactivated?" is yes, across everything it should cover. Suppliers re-checked: the answer to "Are existing suppliers re-checked periodically, not only when they are first added?" is yes, across everything it should cover. Directors and owners, including those behind holding companies, are identified for every new supplier from an independent source. | Head of procurement<br>60 days | Controls are added one at a time and the scheme stays open through the gaps between them. |
| **Put first the controls that other controls depend on.** | Building the dependent checks first produces controls that cannot run. | Sequence directors compared with staff, dormant suppliers deactivated, services confirmed and three-way match ahead of the checks that rely on them. | Head of procurement<br>30 days | Effort is spent on checks that cannot operate. |
| **Decide whether to keep relying on 1 control reported in place whose supporting practices were reported as gaps.** | A self-reported control that its own practices do not support can give management comfort it has not earned. | Ask each process owner to confirm in writing how the control works without the missing practices, and close the practices in the next 60 days. | People, learning and ethics<br>30 days | The scheme is treated as covered when it may not be. |
| **Require the 7 outstanding answers within 30 days, and treat any that cannot be given as an open risk.** | Nothing is concluded about a control nobody has answered for; until it is answered the scheme it stops is unknown, not covered. | Assign each outstanding answer to a named person with a date. | Chief Executive / Managing Director<br>30 days | Schemes stay unknown and cannot be prioritised. |
| **Have the board or its audit committee receive the status of the 22 first-priority schemes each month until they are closed.** | Monthly reporting keeps the schemes visible to the people who can remove blockers. | A one-page scheme status: owner, controls in place, controls outstanding, next date. | Chief Executive / Managing Director<br>30 days | Progress is not visible until the next assessment. |

A recommended direction is MK methodology. The decision remains management's.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# The 12-month implementation programme

60 implementation actions, followed by 41 embed-and-evidence checkpoints, and 41 assure-and-review checkpoints across the 12-month programme. 142 programme objects in total, each with an owner, a deliverable and a test that shows it is complete.

| HORIZON | WORK TYPE | COUNT | PROGRAMMES ADVANCED IN THIS HORIZON |
|---|---|---|---|
| **30 days** | Implement | 7 | Supplier and payment integrity · Payroll integrity · Identity and access challenge |
| **60 days** | Implement | 16 | Supplier and payment integrity · Payroll integrity · Detection and exception review · Identity and access challenge · Cash custody · Stock and asset custody · Incident response and evidence integrity |
| **90 days** | Implement | 37 | Culture and continuous improvement · Supplier and payment integrity · Payroll integrity · Identity and access challenge · Detection and exception review · Stock and asset custody · Incident response and evidence integrity |
| **3-6 months** | Embed & evidence | 41 | Culture and continuous improvement · Supplier and payment integrity · Payroll integrity · Identity and access challenge · Detection and exception review · Stock and asset custody · Incident response and evidence integrity |
| **6-12 months** | Assure & review | 41 | Culture and continuous improvement · Supplier and payment integrity · Payroll integrity · Identity and access challenge · Detection and exception review · Stock and asset custody · Incident response and evidence integrity |

Every programme item, with its dependency and completion criterion, is in Appendix E.

**IMPLEMENTATION SYNTHESIS**

Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# The measurement framework

Each programme carries effectiveness measures drawn from the control designs behind it. These are the signals management should expect to see, not a claim that they exist today.

| PROGRAMME | MEASURES | CONTROLS | ACCOUNTABLE FOR REPORTING |
|---|---|---|---|
| **Supplier and payment integrity** | 15 | 15 | Head of procurement |
| **Identity and access challenge** | 14 | 14 | Head of IT |
| **Payroll integrity** | 10 | 10 | HR |
| **Detection and exception review** | 8 | 8 | Commercial |
| **Stock and asset custody** | 8 | 8 | Operations |
| **Incident response and evidence integrity** | 2 | 2 | Head of IT |
| **Culture and continuous improvement** | 1 | 1 | People, learning and ethics |
| **Cash custody** | 1 | 1 | Operations |

The individual measures are in Appendix F.

**CONCLUSION**

Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# Finding register

Every material finding the assessment produced. "Assessment indication" is what the responses record; it is self-reported and has not been verified.

| ID | DOMAIN | ASSESSMENT INDICATION | MATERIALITY | FRAUD MECHANISM | RISK | CONTROL |
|---|---|---|---|---|---|---|
| MF-FS-D4-05 D4-V-01 | Third parties and supply chain | Invoices are paid without being checked against what was approved or received. Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid. | control failure CRITICAL | Overbilling, fictitious deliveries or inflated rates are paid. The method links it to unauthorised commitments and approval override, duplicate or false invoices, overpricing, overbilling and inflated variations, goods or services paid for but not received, counterfeit, substituted or substandard goods and misrepresented supplier credentials. | RISK-FS-D4-05 | CI-FS-D4-05 |
| MF-FS-D4-02 D4-B-12 | Third parties and supply chain | A follow-up call from the 'supplier' is accepted as confirmation. Changed supplier bank details are the most common route for payment fraud, and cloned voices now defeat call-backs that rely on recognition. | control failure CRITICAL | A fraudster, often impersonating the supplier by email, voice or video, has the bank account changed. The method links it to payment redirection through false bank details or impersonation. | RISK-FS-D4-02 | CI-FS-D4-02 |
| MF-FS-D5-01 D5-M-05 | People, payroll and insider risk | Bank detail changes are made as requested. Salary redirection through fake bank change requests is common and fast. | control failure CRITICAL | A request that appears to come from an employee changes where their salary is paid. The method links it to salary redirection through changed bank details, ghost or fictitious employees and payees and unauthorised pay increases, allowances or deductions. | RISK-FS-D5-01 | CI-FS-D5-01 |
| MF-FS-D9-02 D9-E-05 | Digital, cyber-enabled and identity fraud | Payment changes received by email are acted on as received. Acting on payment instructions received by email is how business email compromise succeeds. | control failure CRITICAL | Changed details or urgent payments are processed on the strength of an email. The method links it to business email compromise and payment redirection and takeover of staff accounts. | RISK-FS-D9-02 | CI-FS-D9-02 |
| MF-FS-D4-04 D4-A-07 | Third parties and supply chain | The same person can order and approve payment. One person who can both order and approve payment can pay a supplier they invented. | control failure CRITICAL | A buyer invents or inflates a purchase and approves its payment. The method links it to unauthorised commitments and approval override, irregular deviations and emergency purchases, kickbacks and bribery, goods or services paid for but not received and duplicate or false invoices. | RISK-FS-D4-04 | CI-FS-D4-04 |
| MF-FS-D9-01 D9-E-01 | Digital, cyber-enabled and identity fraud | Email accounts are protected by passwords only. Most business email compromise starts with an account that has no multi-factor authentication. | control failure CRITICAL | A mailbox without strong sign-in is used to send or intercept payment instructions. The method links it to takeover of staff accounts, business email compromise and payment redirection, spoofed or lookalike email in the organisation's name, criminals impersonating the organisation to customers, suppliers and the public and slow response that lets losses grow. | RISK-FS-D9-01 | CI-FS-D9-01 |
| MF-FS-D4-01 D4-O-01 | Third parties and supply chain | Checks happen only when someone thinks to do them. Fictitious suppliers enter through onboarding that can be skipped. | control gap CRITICAL | An insider or outsider adds a supplier that does not exist and invoices it. The method links it to fictitious or shell suppliers, undisclosed conflicts of interest, misrepresented supplier credentials and duplicate or false invoices. | RISK-FS-D4-01 | CI-FS-D4-01 |

| | | | | | | |
|---|---|---|---|---|---|---|
| MF-FS-D4-09 D4-X-01 | Third parties and supply chain | Buying staff do not declare interests. Buyers take kickbacks is a scheme the method asks about for organisations with this profile. | control failure | A long-standing buyer-supplier relationship hides favours. The method links it to undisclosed conflicts of interest, kickbacks and bribery and bid rigging and collusion. | RISK-FS-D4-09 | CI-FS-D4-09 |
| MF-FS-D7-01 D7-R-01 | Customers, revenue and products | Approval is sought only for large refunds or when staff are unsure. Refunds processed and approved by one person are a classic way to steal. | control gap CRITICAL | One person raises and approves refunds or credit notes to themselves or accomplices. The method links it to false refunds, credit notes and returns, stolen or diverted customer payments, including lapping and fictitious sales and commission fraud. | RISK-FS-D7-01 | CI-FS-D7-01 |
| MF-FS-D7-03 D7-C-02 | Customers, revenue and products | Documents are checked only if something looks wrong. Application fraud with fabricated documents drives credit losses. | control gap CRITICAL | Fake payslips and bank statements, now easy to generate, secure credit that is never repaid. The method links it to application and credit fraud using forged documents, unauthorised discounts, price overrides and side agreements, customers using false or stolen identities and stolen or diverted customer payments, including lapping. | RISK-FS-D7-03 | CI-FS-D7-03 |
| MF-FS-D8-07 D8-F-03 | Assets, cash and inventory | Fuel purchases are not compared with vehicle use. Fuel and fleet are misused is a scheme the method asks about for organisations with this profile. | control failure | Fuel cards or vehicles are used privately or fraudulently. The method links it to fuel card fraud and vehicle misuse, short deliveries and theft in transit, fake proof of payment, deposit or delivery, inflated maintenance and parts fraud and organised theft of high-value materials. | RISK-FS-D8-07 | CI-FS-D8-07 |
| MF-FS-D9-03 D9-I-01 | Digital, cyber-enabled and identity fraud | Some staff check unusual requests, depending on their own judgement. Voices and faces can be cloned, so only an agreed verification method holds. | control gap CRITICAL | A caller who sounds or looks like a known person is believed. The method links it to deepfake voice and video impersonation of executives and staff, business email compromise and payment redirection, takeover of staff accounts and SIM swaps and intercepted one-time PINs. | RISK-FS-D9-03 | CI-FS-D9-03 |
| MF-FS-D9-12 D9-R-02 | Digital, cyber-enabled and identity fraud | There is no plan; each case would be handled from scratch. A compromise is not contained quickly is a scheme the method asks about for organisations with this profile. | control failure | Accounts stay compromised while suppliers and customers keep receiving instructions. The method links it to slow response that lets losses grow, business email compromise and payment redirection and takeover of staff accounts. | RISK-FS-D9-12 | CI-FS-D9-12 |
| MF-FS-D5-02 D5-P-01 | People, payroll and insider risk | Someone else looks at totals, but not the detail. A payroll that nobody independent reviews before payment is where ghost employees hide. | control gap CRITICAL | Fictitious or departed people stay on the payroll. The method links it to ghost or fictitious employees and payees, unauthorised pay increases, allowances or deductions, salary redirection through changed bank details, manipulation of the payroll run or payment file, payments to people after they leave and false or inflated expense claims. | RISK-FS-D5-02 | CI-FS-D5-02 |
| MF-FS-D7-02 D7-O-04 | Customers, revenue and products | Most changes are verified with the customer, but sales staff can still make them. Changed customer details are how refunds and goods are redirected. | control gap CRITICAL | Refund accounts, delivery addresses or contact numbers are changed without the customer. The method links it to customers using false or stolen identities, false refunds, credit notes and returns, stolen or diverted customer payments, including lapping and fictitious sales and commission fraud. | RISK-FS-D7-02 | CI-FS-D7-02 |

| | | | | | | |
|---|---|---|---|---|---|---|
| MF-FS-D4-13<br>D4-K-04 | Third parties and supply chain | No<br>Variations inflate the agreed value is a scheme the method asks about for organisations with this profile. | control failure | Extra scope or rates are approved after the work is done. The method links it to overpricing, overbilling and inflated variations, irregular deviations and emergency purchases, kickbacks and bribery, goods or services paid for but not received, diverted rebates and supplier incentives, undisclosed conflicts of interest and fictitious or shell suppliers. | RISK-FS-D4-13 | CI-FS-D4-13 |
| MF-FS-D8-02<br>D8-K-02 | Assets, cash and inventory | The stores team counts, and someone else glances at the results.<br>Counts done by the people who hold the stock can hide its theft. | control gap<br>CRITICAL | The people who hold stock also count it. The method links it to theft of stock and materials, false write-offs and adjustments that hide theft, short deliveries and theft in transit, organised theft of high-value materials and fake proof of payment, deposit or delivery. | RISK-FS-D8-02 | CI-FS-D8-02 |
| MF-FS-D9-07<br>D9-A-01 | Digital, cyber-enabled and identity fraud | These systems are protected by passwords only.<br>Systems that move money are accessed without strong sign-in is a scheme the method asks about for organisations with this profile. | control failure | Remote access, cloud or banking systems rely on passwords alone. The method links it to takeover of staff accounts, misuse of administrator and third-party access and theft and sale of personal information. | RISK-FS-D9-07 | CI-FS-D9-07 |
| MF-FS-D5-07<br>D5-P-07 | People, payroll and insider risk | No<br>The payroll payment file is altered after approval is a scheme the method asks about for organisations with this profile. | control failure | Account numbers or amounts change between approval and the bank. The method links it to manipulation of the payroll run or payment file, salary redirection through changed bank details and misuse of staff loans, advances and deductions. | RISK-FS-D5-07 | CI-FS-D5-07 |
| MF-FS-D5-11<br>D5-B-02 | People, payroll and insider risk | No<br>Labour brokers invoice for workers who were not there is a scheme the method asks about for organisations with this profile. | control failure | Broker or casual worker numbers are inflated. The method links it to labour broker overbilling, ghost or fictitious employees and payees and salary redirection through changed bank details. | RISK-FS-D5-11 | CI-FS-D5-11 |
| MF-FS-D7-05<br>D7-K-02 | Customers, revenue and products | Assessors rely on their own experience, without set indicators.<br>Claims fraud is the main fraud risk for organisations that pay claims. | control gap<br>CRITICAL | False warranty, guarantee or insurance claims are paid. The method links it to false or inflated claims and stolen or diverted customer payments, including lapping. | RISK-FS-D7-05 | CI-FS-D7-05 |
| MF-FS-D5-04<br>D5-R-03 | People, payroll and insider risk | ID documents are checked by eye for some appointments.<br>False identities enter at hiring and are hard to remove afterwards. | control gap<br>CRITICAL | Someone is employed under a stolen or invented identity or false qualifications. The method links it to ghost or fictitious employees and payees, nepotism and undisclosed links in hiring and false identity or credentials at hiring. | RISK-FS-D5-04 | CI-FS-D5-04 |
| MF-FS-D5-05<br>D5-R-13 | People, payroll and insider risk | Some appointments include a further check, depending on the manager.<br>Deepfake and stand-in candidates are now a recorded way into organisations. | control gap<br>CRITICAL | A remote hire is not the person who was interviewed or who does the work. The method links it to false identity or credentials at hiring, ghost or fictitious employees and payees and remote employees who are not the person appointed, or who do not do the work. | RISK-FS-D5-05 | CI-FS-D5-05 |

| | | | | | | |
|---|---|---|---|---|---|---|
| MF-FS-D5-12<br>D5-K-01 | People, payroll and insider risk | Most people in sensitive roles take block leave, with someone else doing their work.<br>An insider in a high-risk role works unchecked is a scheme the method asks about for organisations with this profile. | control gap | Someone who never hands over work conceals an ongoing fraud. The method links it to concealment by people who control a process alone, misuse of privileged system access, false identity or credentials at hiring, insider fraud that goes unnoticed despite visible warning signs and payments to people after they leave. | RISK-FS-D5-12 | CI-FS-D5-12 |
| MF-FS-D9-04<br>D9-H-01 | Digital, cyber-enabled and identity fraud | Multi-factor authentication is offered, but customers can opt out.<br>Customer accounts without takeover protection are drained with stolen passwords. | control gap<br>CRITICAL | Stolen passwords or SIM swaps are used to drain customer accounts. The method links it to customer account takeover and digital channel fraud, slow response that lets losses grow and manipulation of customer-facing AI tools. | RISK-FS-D9-04 | CI-FS-D9-04 |
| MF-FS-D4-03<br>D4-O-08 | Third parties and supply chain | Accounts are verified through a bank or third-party service for most new suppliers.<br>Confirming account ownership at onboarding stops both fictitious and impersonated suppliers being paid into accounts they do not own; added after the review's isolated-weakness probe. | control gap<br>CRITICAL | Payments go to an employee's or fraudster's account from the first invoice. The method links it to payment redirection through false bank details or impersonation, fictitious or shell suppliers and misrepresented supplier credentials. | RISK-FS-D4-03 | CI-FS-D4-03 |
| MF-FS-D4-10<br>D4-Q-04 | Third parties and supply chain | No<br>Purchase cards or petty cash are misused is a scheme the method asks about for organisations with this profile. | control failure | Personal purchases or split transactions go unreviewed. The method links it to purchase card and petty cash misuse and order splitting to avoid approval limits. | RISK-FS-D4-10 | CI-FS-D4-10 |
| MF-FS-D4-11<br>D4-T-03 | Third parties and supply chain | No<br>Intermediaries pay bribes or inflate fees is a scheme the method asks about for organisations with this profile. | control failure | Agents act improperly or bill for work not done. The method links it to bribery and misconduct through intermediaries, fictitious or shell suppliers, overpricing, overbilling and inflated variations and payment redirection through false bank details or impersonation. | RISK-FS-D4-11 | CI-FS-D4-11 |
| MF-FS-D5-08<br>D5-C-01 | People, payroll and insider risk | No<br>Cash wages are stolen or paid to ghosts is a scheme the method asks about for organisations with this profile. | control failure | Cash pay-outs are not witnessed or reconciled. The method links it to theft of cash wages and ghost or fictitious employees and payees. | RISK-FS-D5-08 | CI-FS-D5-08 |
| MF-FS-D7-11<br>D7-P-02 | Customers, revenue and products | No<br>Prices are overridden or side deals made is a scheme the method asks about for organisations with this profile. | control failure | Discounts or terms favour a customer in return for a kickback. The method links it to unauthorised discounts, price overrides and side agreements and fictitious sales and commission fraud. | RISK-FS-D7-11 | CI-FS-D7-11 |
| MF-FS-D7-12<br>D7-H-01 | Customers, revenue and products | No<br>Agents report fictitious sales is a scheme the method asks about for organisations with this profile. | control failure | Commission is paid on customers who do not exist or soon cancel. The method links it to fictitious sales and commission fraud and customers using false or stolen identities. | RISK-FS-D7-12 | CI-FS-D7-12 |
| MF-FS-D8-01<br>D8-C-03 | Assets, cash and inventory | Takings are reconciled occasionally, or only when there is a shortage.<br>Daily reconciliation of takings is the main control over cash theft. | control gap<br>CRITICAL | Takings are under-recorded or removed before banking. The method links it to theft of cash, sales skimmed before they are recorded and fake proof of payment, deposit or delivery. | RISK-FS-D8-01 | CI-FS-D8-01 |

| | | | | | | |
|---|---|---|---|---|---|---|
| MF-FS-D9-05<br>D9-P-04 | Digital, cyber-enabled and identity fraud | A compromise would be handled as it happens, without a set process.<br>POPIA section 22 requires notification as soon as reasonably possible. | control gap<br>CRITICAL | The Regulator and affected people are not told, so they cannot protect themselves. The method links it to theft and sale of personal information, criminals impersonating the organisation to customers, suppliers and the public and slow response that lets losses grow. | RISK-FS-D9-05 | CI-FS-D9-05 |
| MF-FS-D5-03<br>D5-T-03 | People, payroll and insider risk | Removal is checked for some leavers.<br>Leavers who stay on the payroll are the commonest ghost employees. | control gap<br>CRITICAL | A leaver keeps being paid, often to an account someone else controls. The method links it to payments to people after they leave. | RISK-FS-D5-03 | CI-FS-D5-03 |
| MF-FS-D4-07<br>D4-V-06 | Third parties and supply chain | A second approval happens sometimes.<br>Supplier payments are released without two approvals is a scheme the method asks about for organisations with this profile. | control gap | One person releases a payment run. The method links it to payment redirection through false bank details or impersonation, duplicate or false invoices, fictitious or shell suppliers, unauthorised commitments and approval override and manipulation of automated invoice approval. | RISK-FS-D4-07 | CI-FS-D4-07 |
| MF-FS-D9-08<br>D9-P-01 | Digital, cyber-enabled and identity fraud | Access is limited for some systems only.<br>Personal information is over-exposed or kept too long is a scheme the method asks about for organisations with this profile. | control gap | Too many people can reach or export personal information, or records outlive their purpose. The method links it to theft and sale of personal information and takeover of staff accounts. | RISK-FS-D9-08 | CI-FS-D9-08 |
| MF-FS-D4-06<br>D4-T-13 | Third parties and supply chain | Access is limited to what the service needs for the main providers.<br>Provider access wider than the service needs is how outsourced processes are abused; now applies wherever processes are outsourced, not only where nothing is bought. | control gap<br>CRITICAL | A provider that handles money, customers or data has wider access than the service needs. The method links it to fraud inside outsourced service providers. | RISK-FS-D4-06 | CI-FS-D4-06 |
| MF-FS-D4-08<br>D4-C-06 | Third parties and supply chain | Criteria exist, but they are sometimes set or changed after bids arrive.<br>A tender is manipulated or purchases are split is a scheme the method asks about for organisations with this profile. | control gap | Specifications, evaluation or thresholds are bent towards a chosen supplier. The method links it to order splitting to avoid approval limits, overpricing, overbilling and inflated variations, manipulated specifications or bid process, bid rigging and collusion, kickbacks and bribery, undisclosed conflicts of interest and irregular deviations and emergency purchases. | RISK-FS-D4-08 | CI-FS-D4-08 |
| MF-FS-D9-06<br>D9-A-05 | Digital, cyber-enabled and identity fraud | Most resets need verification through a trusted route, such as the person's manager or a number on file.<br>A help desk reset hands an attacker access is a scheme the method asks about for organisations with this profile. | control gap | An impersonator persuades the help desk to reset a password or authenticator. The method links it to social engineering of the IT help desk, takeover of staff accounts and misuse of administrator and third-party access. | RISK-FS-D9-06 | CI-FS-D9-06 |
| MF-FS-D7-09<br>D7-B-01 | Customers, revenue and products | Billing depends on staff remembering.<br>Sales are not billed or receipts are diverted is a scheme the method asks about for organisations with this profile. | control gap | Goods or services are provided without an invoice, or payments are taken off the books. The method links it to goods or services supplied without being billed, stolen or diverted customer payments, including lapping, unauthorised discounts, price overrides and side agreements and fictitious sales and commission fraud. | RISK-FS-D7-09 | CI-FS-D7-09 |

| | | | | | | |
|---|---|---|---|---|---|---|
| MF-FS-D9-09 D9-M-01 | Digital, cyber-enabled and identity fraud | Staff have been told about SIM swaps, but nothing has been changed.<br>A SIM swap defeats one-time PIN approvals is a scheme the method asks about for organisations with this profile. | control gap | Approvals sent by SMS are intercepted. The method links it to SIM swaps and intercepted one-time PINs and customer account takeover and digital channel fraud. | RISK-FS-D9-09 | CI-FS-D9-09 |
| MF-FS-D5-10 D5-E-02 | People, payroll and insider risk | Partly: only in some areas, cases or periods<br>Expenses and advances are abused is a scheme the method asks about for organisations with this profile. | control gap | False or inflated claims are paid. The method links it to false or inflated expense claims and misuse of staff loans, advances and deductions. | RISK-FS-D5-10 | CI-FS-D5-10 |
| MF-FS-D8-04 D8-A-08 | Assets, cash and inventory | Partly: only in some areas, cases or periods<br>Data leaves on disposed or reissued devices is a scheme the method asks about for organisations with this profile. | control gap | Devices are sold, reissued or returned without being wiped. | RISK-FS-D8-04 | CI-FS-D8-04 |
| MF-FS-D9-10 D9-G-02 | Digital, cyber-enabled and identity fraud | Partly: only in some areas, cases or periods<br>An AI assistant is manipulated by hidden instructions is a scheme the method asks about for organisations with this profile. | control gap | Instructions planted in emails or documents make an assistant leak data or act. | RISK-FS-D9-10 | CI-FS-D9-10 |
| MF-FS-D7-10 D7-B-04 | Customers, revenue and products | The bank account appears on invoices, but there is no warning about changes.<br>Customers pay fraudsters impersonating the organisation is a scheme the method asks about for organisations with this profile. | control gap | Customers receive fake banking details and pay the wrong account. The method links it to customers defrauded by criminals impersonating the organisation, stolen or diverted customer payments, including lapping and customers using false or stolen identities. | RISK-FS-D7-10 | CI-FS-D7-10 |
| MF-FS-D8-05 D8-D-04 | Assets, cash and inventory | Payment is confirmed in the bank for larger sales only.<br>Assets or scrap are sold off cheaply or without payment is a scheme the method asks about for organisations with this profile. | control gap | Disposals favour insiders or goods leave before payment. The method links it to disposals at undervalue or to connected parties, fake proof of payment, deposit or delivery, theft and under-recording of scrap and by-products and organised theft of high-value materials. | RISK-FS-D8-05 | CI-FS-D8-05 |
| MF-FS-D3-11 D3-N-02 | Ethics, integrity and anti-corruption | Partly: only in some areas, cases or periods<br>Donations or sponsorships channel bribes is a scheme the method asks about for organisations with this profile. | control gap | A payment to a cause linked to a decision-maker buys influence. The method links it to donations and sponsorships used as disguised bribes, undeclared conflicts of interest steering decisions, corporate criminal liability for bribery by people acting for the organisation and bribes paid or received to win or keep business. | RISK-FS-D3-11 | CI-FS-D3-11 |
| MF-FS-D5-09 D5-L-05 | People, payroll and insider risk | It is set out or agreed, but not yet working in practice<br>Hours and overtime are inflated is a scheme the method asks about for organisations with this profile. | control gap | Unworked hours or overtime are approved and paid. The method links it to timesheet, overtime and leave abuse, payments to people after they leave and unauthorised pay increases, allowances or deductions. | RISK-FS-D5-09 | CI-FS-D5-09 |
| MF-FS-D8-06 D8-I-10 | Assets, cash and inventory | Partly: only in some areas, cases or periods<br>Goods are released to an impostor is a scheme the method asks about for organisations with this profile. | control gap | A changed delivery or collection instruction sends goods to a fraudster. The method links it to short deliveries and theft in transit and fake proof of payment, deposit or delivery. | RISK-FS-D8-06 | CI-FS-D8-06 |

| | | | | | | |
|---|---|---|---|---|---|---|
| MF-FS-D9-14 D9-E-02 | Digital, cyber-enabled and identity fraud | Partly<br>Spoofed email in the organisation's name deceives staff, suppliers or customers is a scheme the method asks about for organisations with this profile. | control gap | Emails that appear to come from the organisation's own domain carry false payment instructions. The method links it to spoofed or lookalike email in the organisation's name and criminals impersonating the organisation to customers, suppliers and the public. | RISK-FS-D9-14 | CI-FS-D9-14 |
| MF-FS-D8-08 D8-T-01 | Assets, cash and inventory | No<br>Goods go missing in transit is a scheme the method asks about for organisations with this profile. | control failure | Loads are short-delivered or diverted. The method links it to theft of stock and materials, short deliveries and theft in transit and organised theft of high-value materials. | RISK-FS-D8-08 | CI-FS-D8-08 |
| MF-FS-D8-09 D8-H-01 | Assets, cash and inventory | No<br>High-value materials are stolen by organised groups is a scheme the method asks about for organisations with this profile. | control failure | Copper, cable, fuel or similar are stolen with insider help. The method links it to organised theft of high-value materials and theft of stock and materials. | RISK-FS-D8-09 | CI-FS-D8-09 |
| MF-FS-D9-11 D9-O-02 | Digital, cyber-enabled and identity fraud | No<br>The organisation's own information helps attackers is a scheme the method asks about for organisations with this profile. | control failure | Published staff details and routines make impersonation easier. The method links it to deepfake voice and video impersonation of executives and staff, business email compromise and payment redirection and criminals impersonating the organisation to customers, suppliers and the public. | RISK-FS-D9-11 | CI-FS-D9-11 |
| MF-FS-D9-13 D9-I-05 | Digital, cyber-enabled and identity fraud | No<br>The organisation is impersonated to defraud others is a scheme the method asks about for organisations with this profile. | control failure | Fake websites, accounts or job adverts in the organisation's name collect money or personal information. The method links it to criminals impersonating the organisation to customers, suppliers and the public. | RISK-FS-D9-13 | CI-FS-D9-13 |
| MF-FS-D4-12 D4-V-15 | Third parties and supply chain | It is set out or agreed, but not yet working in practice<br>Procurement anomalies are never noticed is a scheme the method asks about for organisations with this profile. | control gap | Patterns such as splitting or duplicates go unseen. The method links it to order splitting to avoid approval limits, overpricing, overbilling and inflated variations, kickbacks and bribery and duplicate or false invoices. | RISK-FS-D4-12 | CI-FS-D4-12 |
| MF-FS-D3-10 D3-C-04 | Ethics, integrity and anti-corruption | Yes, across everything it should cover<br>Staff do not know or understand what is expected is a scheme the method asks about for organisations with this profile. | assurance priority | Expectations are not communicated in a way people understand, and nobody checks. The method links it to unclear standards, so misconduct is excused as normal practice, inconsistent consequences that signal the rules do not apply to everyone, staff unable to recognise fraud, including AI-enabled schemes and corporate criminal liability for bribery by people acting for the organisation. | RISK-FS-D3-10 | CI-FS-D3-10 |
| MF-FS-D7-14 D7-M-08 | Customers, revenue and products | Partly: only in some areas, cases or periods<br>Customers are wrongly blocked on a fraud flag is a scheme the method asks about for organisations with this profile. | control gap | An automated flag is treated as proof and a customer is penalised without review. The method links it to application and credit fraud using forged documents, false or inflated claims, false refunds, credit notes and returns and stolen or diverted customer payments, including lapping. | RISK-FS-D7-14 | CI-FS-D7-14 |

| | | | | | | |
|---|---|---|---|---|---|---|
| MF-FS-D8-11 D8-M-01 | Assets, cash and inventory | It is set out or agreed, but not yet working in practice<br>Losses are never tracked is a scheme the method asks about for organisations with this profile. | control gap | Shrinkage and losses are written off without analysis. The method links it to theft of cash, theft of stock and materials and misappropriation of fixed and portable assets. | RISK-FS-D8-11 | CI-FS-D8-11 |
| MF-FS-D7-13 D7-L-02 | Customers, revenue and products | It is set out or agreed, but not yet working in practice<br>Vouchers and loyalty points are abused is a scheme the method asks about for organisations with this profile. | control gap | Staff issue or redeem value to themselves or associates. The method links it to voucher, loyalty and promotion abuse. | RISK-FS-D7-13 | CI-FS-D7-13 |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# Fraud risk register

Risks implied by the assessed control positions. No likelihood, monetary value or incident frequency is assigned, because the assessment does not support one.

| ID | RISK | CURRENT CONTROL POSITION | REQUIRED TREATMENT | OWNER ROLE |
|---|---|---|---|---|
| RISK-FS-D3-10<br>MF-FS-D3-10 | **Because its control is reported in place while training on joining (only in some areas, cases or periods), there is a risk that expectations are not communicated in a way people understand, and nobody checks.** | Training on joining: only in some areas, cases or periods. | Training on joining: the answer to "Do all employees receive fraud and ethics training when they join?" is yes, across everything it should cover. | Ethics officer or company secretary |
| RISK-FS-D3-11<br>MF-FS-D3-11 | **Because the controls that stop it were reported as gaps: recipients checked for links (only in some areas, cases or periods), there is a risk that a payment to a cause linked to a decision-maker buys influence.** | Recipients checked for links: only in some areas, cases or periods. | Recipients checked for links: the answer to "Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed?" is yes, across everything it should cover. | Ethics officer or company secretary |
| RISK-FS-D4-01<br>MF-FS-D4-01 | **Because the controls that stop it were reported as gaps: new supplier process (only in some areas, cases or periods), directors compared with staff (not in place), dormant suppliers deactivated (not in place) and suppliers re-checked (set out but not yet working in practice), there is a risk that an insider or outsider adds a supplier that does not exist and invoices it. Fictitious suppliers enter through onboarding that can be skipped.** | Checks happen only when someone thinks to do them. Directors compared with staff: not in place. Dormant suppliers deactivated: not in place. Suppliers re-checked: set out but not yet working in practice. Owners are identified only when something raises a concern. | Every new supplier goes through a defined process, with set checks and an approval, before it can be paid. Directors compared with staff: the answer to "Do you compare supplier directors, owners, addresses or bank accounts with your employee records?" is yes, across everything it should cover. Dormant suppliers deactivated: the answer to "Are suppliers that have not been used for a set period deactivated?" is yes, across everything it should cover. Suppliers re-checked: the answer to "Are existing suppliers re-checked periodically, not only when they are first added?" is yes, across everything it should cover. Directors and owners, including those behind holding companies, are identified for every new supplier from an independent source. | Head of procurement or CFO |
| RISK-FS-D4-02<br>MF-FS-D4-02 | **Because the controls that stop it were reported as gaps: familiar caller still verified (not in place) and change confirmed with supplier (only in some areas, cases or periods), there is a risk that a fraudster, often impersonating the supplier by email, voice or video, has the bank account changed. Changed supplier bank details are the most common route for payment fraud, and cloned voices now defeat call-backs that rely on recognition.** | A follow-up call from the 'supplier' is accepted as confirmation. Changes are confirmed, but sometimes using contact details taken from the request itself. | The procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why. Every change is confirmed with the supplier using contact details already on file before it takes effect. | Head of procurement or CFO |
| RISK-FS-D4-03<br>MF-FS-D4-03 | **Because the controls that stop it were reported as gaps: bank account verified (only in some areas, cases or periods), there is a risk that payments go to an employee's or fraudster's account from the first invoice. Confirming account ownership at onboarding stops both fictitious and impersonated suppliers being paid into accounts they do not own; added after the review's isolated-weakness probe.** | Accounts are verified through a bank or third-party service for most new suppliers. | Every new supplier's account is verified through a bank or third-party service before the first payment. | Head of procurement or CFO |
| RISK-FS-D4-04<br>MF-FS-D4-04 | **Because the controls that stop it were reported as gaps: orderer is not payment approver (not in place), there is a risk that a buyer invents or inflates a purchase and approves its payment. One person who can both order and approve payment can pay a supplier they invented.** | The same person can order and approve payment. | The duties are always separated, or any exception is approved and recorded. | Head of procurement or CFO |

| ID | Risk | Position | Required treatment | Owner role |
|---|---|---|---|---|
| RISK-FS-D4-05<br>MF-FS-D4-05 | **Because the controls that stop it were reported as gaps: three-way match (not in place), quantities checked (not in place), services confirmed (not in place) and approved order before commitment (only in some areas, cases or periods), there is a risk that overbilling, fictitious deliveries or inflated rates are paid. Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid.** | Invoices are paid without being checked against what was approved or received. Quantities checked: not in place. Services confirmed: not in place. Most purchases are approved before commitment, through a purchase order or another record. Receipt is recorded for most deliveries, but not always before payment. | Every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first. Quantities checked: the answer to "Are delivered quantities checked against the delivery note and the order?" is yes, across everything it should cover. Services confirmed: the answer to "For services, does the person receiving the service confirm it was delivered before payment?" is yes, across everything it should cover. Every purchase is approved by someone with the authority to do so before the organisation commits, and the approval is recorded. Receipt is always recorded before the related invoice is paid. | Head of procurement or CFO |
| RISK-FS-D4-06<br>MF-FS-D4-06 | **Because the controls that stop it were reported as gaps: provider access limited (only in some areas, cases or periods), there is a risk that a provider that handles money, customers or data has wider access than the service needs. Provider access wider than the service needs is how outsourced processes are abused; now applies wherever processes are outsourced, not only where nothing is bought.** | Access is limited to what the service needs for the main providers. | Every provider's access is limited to what the service needs, logged and reviewed at least once a year. | Head of procurement or CFO |
| RISK-FS-D4-07<br>MF-FS-D4-07 | **Because the controls that stop it were reported as gaps: two approvers on banking platform (only in some areas, cases or periods), there is a risk that one person releases a payment run.** | A second approval happens sometimes. | The banking platform requires two separate people to approve every supplier payment. | Head of procurement or CFO |
| RISK-FS-D4-08<br>MF-FS-D4-08 | **Because the controls that stop it were reported as gaps: evaluation against set criteria (only in some areas, cases or periods) and quote and tender thresholds (not in place), there is a risk that specifications, evaluation or thresholds are bent towards a chosen supplier.** | Criteria exist, but they are sometimes set or changed after bids arrive. Quote and tender thresholds: not in place. | Every competitive purchase is evaluated by more than one person against criteria set before bids are received, and scores are recorded. Quote and tender thresholds: the answer to "Are there set amounts above which multiple quotes or a formal tender are required?" is yes, across everything it should cover. | Head of procurement or CFO |
| RISK-FS-D4-09<br>MF-FS-D4-09 | **Because the controls that stop it were reported as gaps: annual interest declarations (not in place), there is a risk that a long-standing buyer-supplier relationship hides favours.** | Buying staff do not declare interests. | Everyone involved in buying declares interests each year and when circumstances change, and declarations are kept on record. | Head of procurement or CFO |
| RISK-FS-D4-10<br>MF-FS-D4-10 | **Because the controls that stop it were reported as gaps: independent reconciliation (not in place), there is a risk that personal purchases or split transactions go unreviewed.** | Independent reconciliation: not in place. | Independent reconciliation: the answer to "Are statements reconciled and reviewed by someone other than the cardholder?" is yes, across everything it should cover. | Head of procurement or CFO |
| RISK-FS-D4-11<br>MF-FS-D4-11 | **Because the controls that stop it were reported as gaps: intermediaries vetted (not in place), there is a risk that agents act improperly or bill for work not done.** | Intermediaries vetted: not in place. | Intermediaries vetted: the answer to "Are intermediaries vetted before appointment, including who owns them and their reputation?" is yes, across everything it should cover. | Head of procurement or CFO |
| RISK-FS-D4-12<br>MF-FS-D4-12 | **Because the controls that stop it were reported as gaps: senior review of supplier payments (set out but not yet working in practice), data reviewed for unusual patterns (not in place), split orders monitored (set out but not yet working in practice) and independent review of procurement (only in some areas, cases or periods), there is a risk that patterns such as splitting or duplicates go unseen.** | Senior review of supplier payments: set out but not yet working in practice. Data reviewed for unusual patterns: not in place. Split orders monitored: set out but not yet working in practice. Independent review of procurement: only in some areas, cases or periods. | Senior review of supplier payments: the answer to "Does someone senior review a list of supplier payments at least once a month?" is yes, across everything it should cover. Data reviewed for unusual patterns: the answer to "Does anyone regularly review procurement and supplier payment data for unusual patterns?" is yes, across everything it should cover. Split orders monitored: the answer to "Do you monitor for several smaller orders to the same supplier that together exceed an approval limit?" is yes, across everything it should cover. Independent review of procurement: the answer to "Has internal audit or an external reviewer examined procurement in the last two years?" is yes, across everything it should cover. | Head of procurement or CFO |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

| ID | Risk | Position | Required treatment | Owner role |
|---|---|---|---|---|
| RISK-FS-D4-13<br>MF-FS-D4-13 | **Because the controls that stop it were reported as gaps: variations approved first (not in place), contract register (not in place), large variations escalated (set out but not yet working in practice) and written supplier contracts (only in some areas, cases or periods), there is a risk that extra scope or rates are approved after the work is done.** | Variations approved first: not in place. Contract register: not in place. Large variations escalated: set out but not yet working in practice. Written supplier contracts: only in some areas, cases or periods. | Variations approved first: the answer to "Must changes to agreed work, such as variations, extensions or extra scope, be approved before the work goes ahead, whether or not there is a written contract?" is yes, across everything it should cover. Contract register: the answer to "Is there a register of all active supplier contracts?" is yes, across everything it should cover. Large variations escalated: the answer to "Are variations above a set percentage of the original value approved at a higher level?" is yes, across everything it should cover. Written supplier contracts: the answer to "Does the organisation sign written contracts with suppliers for ongoing or significant work?" is yes, across everything it should cover. | Head of procurement or CFO |
| RISK-FS-D5-01<br>MF-FS-D5-01 | **Because the controls that stop it were reported as gaps: bank changes confirmed with employee (not in place), there is a risk that a request that appears to come from an employee changes where their salary is paid. Salary redirection through fake bank change requests is common and fast.** | Bank detail changes are made as requested. | Every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect. | HR or payroll manager |
| RISK-FS-D5-02<br>MF-FS-D5-02 | **Because the controls that stop it were reported as gaps: payroll reviewed by another person (only in some areas, cases or periods), headcount verification done (not in place) and independent review of payroll (only in some areas, cases or periods), there is a risk that fictitious or departed people stay on the payroll. A payroll that nobody independent reviews before payment is where ghost employees hide.** | Someone else looks at totals, but not the detail. Headcount verification done: not in place. Independent review of payroll: only in some areas, cases or periods. | Every payroll run is reviewed before payment by someone who did not prepare it, and the review is recorded. Headcount verification done: the answer to "Has the organisation matched the people on payroll to real employees, through a headcount or verification exercise, in the last two years?" is yes, across everything it should cover. Independent review of payroll: the answer to "Has internal audit or an external reviewer examined payroll in the last two years?" is yes, across everything it should cover. | HR or payroll manager |
| RISK-FS-D5-03<br>MF-FS-D5-03 | **Because the controls that stop it were reported as gaps: leavers removed before next run (only in some areas, cases or periods), there is a risk that a leaver keeps being paid, often to an account someone else controls. Leavers who stay on the payroll are the commonest ghost employees.** | Removal is checked for some leavers. | Every leaver is confirmed as removed before the next pay run, using the HR leaver list. | HR or payroll manager |
| RISK-FS-D5-04<br>MF-FS-D5-04 | **Because the controls that stop it were reported as gaps: identity verified (only in some areas, cases or periods) and qualifications verified (only in some areas, cases or periods), there is a risk that someone is employed under a stolen or invented identity or false qualifications. False identities enter at hiring and are hard to remove afterwards.** | ID documents are checked by eye for some appointments. Certificates are accepted as presented. | Every new employee's identity is verified against Home Affairs records, for example through a verification service, before they start. Every qualification relied on for an appointment is verified with the issuing institution or through SAQA before the offer is final. | HR or payroll manager |
| RISK-FS-D5-05<br>MF-FS-D5-05 | **Because the controls that stop it were reported as gaps: remote appointee identity confirmed (only in some areas, cases or periods), there is a risk that a remote hire is not the person who was interviewed or who does the work. Deepfake and stand-in candidates are now a recorded way into organisations.** | Some appointments include a further check, depending on the manager. | Every remote appointee is confirmed through an in-person meeting or an identity check designed to resist replayed and injected video before access and pay are set up, and failed checks are reviewed by a person. | HR or payroll manager |
| RISK-FS-D5-07<br>MF-FS-D5-07 | **Because the controls that stop it were reported as gaps: payment file protected (not in place), there is a risk that account numbers or amounts change between approval and the bank.** | Payment file protected: not in place. | Payment file protected: the answer to "Is the payroll payment file protected so that a change between approval and upload to the bank would be prevented or detected, for example through a secure bank connection or a file check that the preparer cannot regenerate?" is yes, across everything it should cover. | HR or payroll manager |

| ID | Risk | Position | Required treatment | Owner role |
|---|---|---|---|---|
| RISK-FS-D5-08<br>MF-FS-D5-08 | **Because the controls that stop it were reported as gaps: two people pay out cash (not in place), there is a risk that cash pay-outs are not witnessed or reconciled.** | Two people pay out cash: not in place. | Two people pay out cash: the answer to "Are cash wages paid out by at least two people together?" is yes, across everything it should cover. | HR or payroll manager |
| RISK-FS-D5-09<br>MF-FS-D5-09 | **Because the controls that stop it were reported as gaps: hours approved by supervisor (set out but not yet working in practice), there is a risk that unworked hours or overtime are approved and paid.** | Hours approved by supervisor: set out but not yet working in practice. | Hours approved by supervisor: the answer to "Are hours approved by a supervisor before they are paid?" is yes, across everything it should cover. | HR or payroll manager |
| RISK-FS-D5-10<br>MF-FS-D5-10 | **Because the controls that stop it were reported as gaps: claims approved by a manager (only in some areas, cases or periods), there is a risk that false or inflated claims are paid.** | Claims approved by a manager: only in some areas, cases or periods. | Claims approved by a manager: the answer to "Is each claim approved by a manager other than the claimant?" is yes, across everything it should cover. | HR or payroll manager |
| RISK-FS-D5-11<br>MF-FS-D5-11 | **Because the controls that stop it were reported as gaps: broker invoices against attendance (not in place), there is a risk that broker or casual worker numbers are inflated.** | Broker invoices against attendance: not in place. | Broker invoices against attendance: the answer to "Are labour broker invoices checked against your own attendance records?" is yes, across everything it should cover. | HR or payroll manager |
| RISK-FS-D5-12<br>MF-FS-D5-12 | **Because the controls that stop it were reported as gaps: block leave required (only in some areas, cases or periods), concerns raised fairly (not in place), support for financial pressure (not in place) and no conflicting duties when covering (set out but not yet working in practice), there is a risk that someone who never hands over work conceals an ongoing fraud.** | Most people in sensitive roles take block leave, with someone else doing their work. Concerns raised fairly: not in place. Support for financial pressure: not in place. No conflicting duties when covering: set out but not yet working in practice. No single point of knowledge: set out but not yet working in practice. | Everyone in a sensitive role takes a block of consecutive leave each year, with their work done by someone else, and exceptions are approved. Concerns raised fairly: the answer to "Is there a defined way for managers to raise and escalate concerns about an employee's behaviour, confidentially and without making accusations?" is yes, across everything it should cover. Support for financial pressure: the answer to "Does the organisation offer support to employees in financial difficulty, such as financial wellness or employee assistance programmes?" is yes, across everything it should cover. No conflicting duties when covering: the answer to "Are people in high-risk roles, such as those who can move money or change master data, kept from holding conflicting duties, even temporarily when they cover for colleagues?" is yes, across everything it should cover. No single point of knowledge: the answer to "Is there enough depth in high-risk roles that no single person is the only one who understands or can perform a critical process?" is yes, across everything it should cover. | HR or payroll manager |
| RISK-FS-D7-01<br>MF-FS-D7-01 | **Because the controls that stop it were reported as gaps: refunds approved independently (only in some areas, cases or periods), returns received before credit (not in place), claim evidence checked for AI (not in place) and refund patterns reviewed (only in some areas, cases or periods), there is a risk that one person raises and approves refunds or credit notes to themselves or accomplices. Refunds processed and approved by one person are a classic way to steal.** | Approval is sought only for large refunds or when staff are unsure. Returns received before credit: not in place. Claim evidence checked for AI: not in place. Refund patterns reviewed: only in some areas, cases or periods. Post-period reversals reviewed: only in some areas, cases or periods. | Every refund and credit note is approved by someone other than the person who processes it. Returns received before credit: the answer to "Is every return matched to the goods physically coming back into stock before a credit is issued?" is yes, across everything it should cover. Claim evidence checked for AI: the answer to "Are photographs and documents supporting refund or return requests checked for manipulation, such as AI-generated images of damage?" is yes, across everything it should cover. Refund patterns reviewed: the answer to "Are refunds and credit notes reviewed for patterns, such as the same employee or customer, or amounts just below approval limits?" is yes, across everything it should cover. Post-period reversals reviewed: the answer to "Are credit notes and reversals raised after a period end reviewed, so sales reversed once targets were met are noticed?" is yes, across everything it should cover. | Commercial or finance manager |

| ID | RISK | POSITION | REQUIRED TREATMENT | OWNER ROLE |
|---|---|---|---|---|
| RISK-FS-D7-02<br>MF-FS-D7-02 | **Because the controls that stop it were reported as gaps: customer detail changes verified (only in some areas, cases or periods), defined onboarding (not in place), shared details flagged (not in place) and business customers verified (only in some areas, cases or periods), there is a risk that refund accounts, delivery addresses or contact numbers are changed without the customer. Changed customer details are how refunds and goods are redirected.** | Most changes are verified with the customer, but sales staff can still make them. Defined onboarding: not in place. Shared details flagged: not in place. Business customers verified: only in some areas, cases or periods. | Every change to refund accounts, addresses and contact numbers is verified with the customer through known details and made by someone outside sales. Defined onboarding: the answer to "Is there a defined process for taking on a new customer or opening an account before goods, services or credit are provided?" is yes, across everything it should cover. Shared details flagged: the answer to "Does the system or a review flag customers who share details, such as ID numbers, phone numbers, addresses or bank accounts, with other customers or with employees?" is yes, across everything it should cover. Business customers verified: the answer to "Are business customers checked as real and registered, for example through CIPC, and is it confirmed who may act for them?" is yes, across everything it should cover. | Commercial or finance manager |
| RISK-FS-D7-03<br>MF-FS-D7-03 | **Because the controls that stop it were reported as gaps: application documents verified (only in some areas, cases or periods), statements sent from the system (not in place), limit and terms changes approved (set out but not yet working in practice) and credit approved independently (only in some areas, cases or periods), there is a risk that fake payslips and bank statements, now easy to generate, secure credit that is never repaid. Application fraud with fabricated documents drives credit losses.** | Documents are checked only if something looks wrong. Statements sent from the system: not in place. Limit and terms changes approved: set out but not yet working in practice. Most credit limits are approved by someone outside sales. Bureau and fraud database checks: only in some areas, cases or periods. | The key information in every application is verified with the source, such as the employer, the bank or a verification service, before credit is approved. Statements sent from the system: the answer to "Are customer statements sent directly from the system, so that an employee cannot hide a diverted payment from the customer?" is yes, across everything it should cover. Limit and terms changes approved: the answer to "Are changes to credit limits and payment terms approved and logged?" is yes, across everything it should cover. Every credit limit is approved by someone other than the salesperson, within set authority levels. Bureau and fraud database checks: the answer to "Are applicants checked with a credit bureau and a fraud database, such as the Southern African Fraud Prevention Service, before credit is approved?" is yes, across everything it should cover. | Commercial or finance manager |
| RISK-FS-D7-05<br>MF-FS-D7-05 | **Because the controls that stop it were reported as gaps: fraud indicators screened (only in some areas, cases or periods), there is a risk that false warranty, guarantee or insurance claims are paid. Claims fraud is the main fraud risk for organisations that pay claims.** | Assessors rely on their own experience, without set indicators. | Every claim is screened against defined indicators, such as early claims, repeat claimants and recurring service providers, and flagged claims are referred. | Commercial or finance manager |
| RISK-FS-D7-09<br>MF-FS-D7-09 | **Because the controls that stop it were reported as gaps: everything supplied is billed (only in some areas, cases or periods), there is a risk that goods or services are provided without an invoice, or payments are taken off the books.** | Billing depends on staff remembering. | Every delivery or service is matched to an invoice, and unbilled items are investigated. | Commercial or finance manager |
| RISK-FS-D7-10<br>MF-FS-D7-10 | **Because the controls that stop it were reported as gaps: customers warned about payment redirection (only in some areas, cases or periods), there is a risk that customers receive fake banking details and pay the wrong account.** | The bank account appears on invoices, but there is no warning about changes. | Every invoice and statement shows the bank account and states that it will never change by email or message alone. | Commercial or finance manager |
| RISK-FS-D7-11<br>MF-FS-D7-11 | **Because the controls that stop it were reported as gaps: non-standard prices approved (not in place), there is a risk that discounts or terms favour a customer in return for a kickback.** | Non-standard prices approved: not in place. | Non-standard prices approved: the answer to "Are prices or discounts outside the standard approved by someone other than the salesperson, within set limits?" is yes, across everything it should cover. | Commercial or finance manager |

| ID | Risk | Position | Required treatment | Owner role |
|---|---|---|---|---|
| RISK-FS-D7-12<br>MF-FS-D7-12 | **Because the controls that stop it were reported as gaps: agent sales verified (not in place), there is a risk that commission is paid on customers who do not exist or soon cancel.** | Agent sales verified: not in place. | Agent sales verified: the answer to "Are sales reported by agents or resellers checked against real customer activity, such as payments received or goods delivered, before commission is paid?" is yes, across everything it should cover. | Commercial or finance manager |
| RISK-FS-D7-13<br>MF-FS-D7-13 | **Because the controls that stop it were reported as gaps: vouchers controlled in the system (set out but not yet working in practice), there is a risk that staff issue or redeem value to themselves or associates.** | Vouchers controlled in the system: set out but not yet working in practice. | Vouchers controlled in the system: the answer to "Are vouchers, gift cards and promotion codes issued and redeemed through a system that prevents duplicates and records who issued them?" is yes, across everything it should cover. | Commercial or finance manager |
| RISK-FS-D7-14<br>MF-FS-D7-14 | **Because the controls that stop it were reported as gaps: human review before a customer is blocked (only in some areas, cases or periods), there is a risk that an automated flag is treated as proof and a customer is penalised without review.** | Human review before a customer is blocked: only in some areas, cases or periods. | Human review before a customer is blocked: the answer to "Before a customer's account is blocked or a claim is declined because of a fraud flag, does a person review the decision?" is yes, across everything it should cover. | Commercial or finance manager |
| RISK-FS-D8-01<br>MF-FS-D8-01 | **Because the controls that stop it were reported as gaps: daily reconciliation (only in some areas, cases or periods), there is a risk that takings are under-recorded or removed before banking. Daily reconciliation of takings is the main control over cash theft.** | Takings are reconciled occasionally, or only when there is a shortage. | Takings at every cash point are reconciled to sales records daily, and every shortage and surplus is investigated. | Operations or financial manager |
| RISK-FS-D8-02<br>MF-FS-D8-02 | **Because the controls that stop it were reported as gaps: independent blind counts (only in some areas, cases or periods), how stock is recorded (not in place), differences explained before adjusting (not in place) and write-offs approved and supervised (not in place), there is a risk that the people who hold stock also count it. Counts done by the people who hold the stock can hide its theft.** | The stores team counts, and someone else glances at the results. How stock is recorded: not in place. Differences explained before adjusting: not in place. Stock is written off by the stores team without approval. Shrinkage tracked: set out but not yet working in practice. | Every count is carried out or observed by people independent of the stores team, counting without sight of system quantities. How stock is recorded: the answer to "How is stock recorded?" is yes, across everything it should cover. Differences explained before adjusting: the answer to "Are count differences investigated and explained before the records are adjusted?" is yes, across everything it should cover. Every write-off is approved at a senior level, and the goods are destroyed or disposed of under independent supervision, with a record. Shrinkage tracked: the answer to "Are shrinkage and loss rates tracked by site, product and shift, and investigated when they rise?" is yes, across everything it should cover. | Operations or financial manager |
| RISK-FS-D8-04<br>MF-FS-D8-04 | **Because the controls that stop it were reported as gaps: devices wiped before disposal (only in some areas, cases or periods), there is a risk that devices are sold, reissued or returned without being wiped.** | Devices wiped before disposal: only in some areas, cases or periods. | Devices wiped before disposal: the answer to "Are laptops, phones and other devices wiped of the organisation's data before they are disposed of, sold, reissued or returned?" is yes, across everything it should cover. | Operations or financial manager |
| RISK-FS-D8-05<br>MF-FS-D8-05 | **Because the controls that stop it were reported as gaps: paid before collection (only in some areas, cases or periods), there is a risk that disposals favour insiders or goods leave before payment.** | Payment is confirmed in the bank for larger sales only. | Payment is confirmed on the organisation's own bank statement before any goods are collected. | Operations or financial manager |
| RISK-FS-D8-06<br>MF-FS-D8-06 | **Because the controls that stop it were reported as gaps: changed collection instructions verified (only in some areas, cases or periods), there is a risk that a changed delivery or collection instruction sends goods to a fraudster.** | Changed collection instructions verified: only in some areas, cases or periods. | Changed collection instructions verified: the answer to "When an instruction to release or collect goods changes, such as a new delivery address or a different collector, is the change verified through known contact details, and is the collector's identity checked at release?" is yes, across everything it should cover. | Operations or financial manager |
| RISK-FS-D8-07<br>MF-FS-D8-07 | **Because the controls that stop it were reported as gaps: fuel matched to distance (not in place), there is a risk that fuel cards or vehicles are used privately or fraudulently.** | Fuel purchases are not compared with vehicle use. | Every vehicle's fuel purchases are compared with tracking data, distance travelled and expected consumption, and exceptions are investigated. | Operations or financial manager |

| ID | Risk | Position | Required treatment | Owner role |
|---|---|---|---|---|
| RISK-FS-D8-08<br>MF-FS-D8-08 | **Because the controls that stop it were reported as gaps: dispatch matched to orders (not in place), there is a risk that loads are short-delivered or diverted.** | Dispatch matched to orders: not in place. | Dispatch matched to orders: the answer to "Is every dispatch matched to an approved order before the goods leave?" is yes, across everything it should cover. | Operations or financial manager |
| RISK-FS-D8-09<br>MF-FS-D8-09 | **Because the controls that stop it were reported as gaps: organised theft assessed (not in place), there is a risk that copper, cable, fuel or similar are stolen with insider help.** | Organised theft assessed: not in place. | Organised theft assessed: the answer to "Is the risk of organised theft, such as theft of copper, cable, metals or fuel, assessed together with the security provider?" is yes, across everything it should cover. | Operations or financial manager |
| RISK-FS-D8-11<br>MF-FS-D8-11 | **Because the controls that stop it were reported as gaps: losses tracked and reported (set out but not yet working in practice), there is a risk that shrinkage and losses are written off without analysis.** | Losses tracked and reported: set out but not yet working in practice. | Losses tracked and reported: the answer to "Are losses of cash, stock and assets tracked over time and by location, and reported to management?" is yes, across everything it should cover. | Operations or financial manager |
| RISK-FS-D9-01<br>MF-FS-D9-01 | **Because the controls that stop it were reported as gaps: multi-factor on all email (not in place), there is a risk that a mailbox without strong sign-in is used to send or intercept payment instructions. Most business email compromise starts with an account that has no multi-factor authentication.** | Email accounts are protected by passwords only. | Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. | Head of IT or IT provider |
| RISK-FS-D9-02<br>MF-FS-D9-02 | **Because the controls that stop it were reported as gaps: email never enough on its own (not in place), there is a risk that changed details or urgent payments are processed on the strength of an email. Acting on payment instructions received by email is how business email compromise succeeds.** | Payment changes received by email are acted on as received. | An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it. | Head of IT or IT provider |
| RISK-FS-D9-03<br>MF-FS-D9-03 | **Because the controls that stop it were reported as gaps: verification for calls, voice notes and video (only in some areas, cases or periods), changes to call-back details verified (only in some areas, cases or periods) and executives and their teams prepared (only in some areas, cases or periods), there is a risk that a caller who sounds or looks like a known person is believed. Voices and faces can be cloned, so only an agreed verification method holds.** | Some staff check unusual requests, depending on their own judgement. Most changes are verified through the old details or another trusted route. Most executives with a public profile have agreed a verification method with their assistants and finance teams. | An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it. Every change to a phone number or email used for verification is confirmed through the previous details or another trusted route before it is used. Every executive with a public voice or face has been briefed and has an agreed verification method that their assistants and finance teams use. | Head of IT or IT provider |
| RISK-FS-D9-04<br>MF-FS-D9-04 | **Because the controls that stop it were reported as gaps: customer logins protected (only in some areas, cases or periods), there is a risk that stolen passwords or SIM swaps are used to drain customer accounts. Customer accounts without takeover protection are drained with stolen passwords.** | Multi-factor authentication is offered, but customers can opt out. | Customer logins are protected with multi-factor authentication, device recognition and limits on repeated failed attempts. | Head of IT or IT provider |
| RISK-FS-D9-05<br>MF-FS-D9-05 | **Because the controls that stop it were reported as gaps: compromises reported as POPIA requires (only in some areas, cases or periods) and affected people warned (not in place), there is a risk that the Regulator and affected people are not told, so they cannot protect themselves. POPIA section 22 requires notification as soon as reasonably possible.** | A compromise would be handled as it happens, without a set process. Affected people warned: not in place. | A procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly. Affected people warned: the answer to "When data is leaked, are affected people warned about follow-up fraud, such as phishing that uses their real details?" is yes, across everything it should cover. | Head of IT or IT provider |
| RISK-FS-D9-06<br>MF-FS-D9-06 | **Because the controls that stop it were reported as gaps: help desk resets verified (only in some areas, cases or periods), there is a risk that an impersonator persuades the help desk to reset a password or authenticator.** | Most resets need verification through a trusted route, such as the person's manager or a number on file. | Every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel. | Head of IT or IT provider |
| RISK-FS-D9-07<br>MF-FS-D9-07 | **Because the controls that stop it were reported as gaps: multi-factor on critical systems (not in place), there is a risk that remote access, cloud or banking systems rely on passwords alone.** | These systems are protected by passwords only. | It is required for remote access, cloud systems, the banking platform and every system that can move money or change master data. | Head of IT or IT provider |

| ID | RISK | POSITION | REQUIRED TREATMENT | OWNER ROLE |
|---|---|---|---|---|
| RISK-FS-D9-08<br>MF-FS-D9-08 | **Because the controls that stop it were reported as gaps: access to personal information limited (only in some areas, cases or periods), there is a risk that too many people can reach or export personal information, or records outlive their purpose.** | Access is limited for some systems only. | In every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged. | Head of IT or IT provider |
| RISK-FS-D9-09<br>MF-FS-D9-09 | **Because the controls that stop it were reported as gaps: approval numbers protected (only in some areas, cases or periods), there is a risk that approvals sent by SMS are intercepted.** | Staff have been told about SIM swaps, but nothing has been changed. | Every number used to approve payments or reset access has a network SIM-swap lock or has been replaced by an authenticator app. | Head of IT or IT provider |
| RISK-FS-D9-10<br>MF-FS-D9-10 | **Because the controls that stop it were reported as gaps: assistant permissions limited (only in some areas, cases or periods), there is a risk that instructions planted in emails or documents make an assistant leak data or act.** | Assistant permissions limited: only in some areas, cases or periods. | Assistant permissions limited: the answer to "Are the permissions of AI assistants limited to what each task needs, so that they cannot make payments, change records or send messages without a person's approval?" is yes, across everything it should cover. | Head of IT or IT provider |
| RISK-FS-D9-11<br>MF-FS-D9-11 | **Because the controls that stop it were reported as gaps: staff guided on what not to share (not in place), there is a risk that published staff details and routines make impersonation easier.** | Staff guided on what not to share: not in place. | Staff guided on what not to share: the answer to "Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling?" is yes, across everything it should cover. | Head of IT or IT provider |
| RISK-FS-D9-13<br>MF-FS-D9-13 | **Because the controls that stop it were reported as gaps: brand impersonation monitored and removed (not in place), there is a risk that fake websites, accounts or job adverts in the organisation's name collect money or personal information.** | Brand impersonation monitored and removed: not in place. | Brand impersonation monitored and removed: the answer to "Does the organisation watch for fake websites, social media accounts and adverts that impersonate it, and have them taken down?" is yes, across everything it should cover. | Head of IT or IT provider |
| RISK-FS-D9-14<br>MF-FS-D9-14 | **Because the controls that stop it were reported as gaps: domain protected against spoofing (only in some areas, cases or periods), there is a risk that emails that appear to come from the organisation's own domain carry false payment instructions.** | Domain protected against spoofing: only in some areas, cases or periods. | Domain protected against spoofing: the answer to "Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject?" is yes, across everything it should cover. | Head of IT or IT provider |
| RISK-FS-D9-12<br>MF-FS-D9-12 | **Because the controls that stop it were reported as gaps: compromise playbook (not in place), there is a risk that accounts stay compromised while suppliers and customers keep receiving instructions.** | There is no plan; each case would be handled from scratch. | A written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles. | Head of IT or IT provider |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# Control blueprint register

Recommended control standard for each finding. This is MK methodology: what good practice requires, not a description of what the organisation currently operates. The assessed state column records what the organisation reported for that control.

**ASSESSED STATE KEY**

- Training on joining: only in some areas, cases or periods.
- Recipients checked for links: only in some areas, cases or periods.
- Checks happen only when someone thinks to do them. Directors compared with staff: not in place. Dormant suppliers deactivated: not in place. Suppliers re-checked: set out but not yet working in practice. Owners are identified only when something raises a concern.
- A follow-up call from the 'supplier' is accepted as confirmation. Changes are confirmed, but sometimes using contact details taken from the request itself.
- Accounts are verified through a bank or third-party service for most new suppliers.
- The same person can order and approve payment.
- Invoices are paid without being checked against what was approved or received. Quantities checked: not in place. Services confirmed: not in place. Most purchases are approved before commitment, through a purchase order or another record. Receipt is recorded for most deliveries, but not always before payment.
- Access is limited to what the service needs for the main providers.
- A second approval happens sometimes.
- Criteria exist, but they are sometimes set or changed after bids arrive. Quote and tender thresholds: not in place.
- Buying staff do not declare interests.
- Independent reconciliation: not in place.
- Intermediaries vetted: not in place.
- Senior review of supplier payments: set out but not yet working in practice. Data reviewed for unusual patterns: not in place. Split orders monitored: set out but not yet working in practice. Independent review of procurement: only in some areas, cases or periods.
- Variations approved first: not in place. Contract register: not in place. Large variations escalated: set out but not yet working in practice. Written supplier contracts: only in some areas, cases or periods.
- Bank detail changes are made as requested.
- Someone else looks at totals, but not the detail. Headcount verification done: not in place. Independent review of payroll: only in some areas, cases or periods.
- Removal is checked for some leavers.
- ID documents are checked by eye for some appointments. Certificates are accepted as presented.
- Some appointments include a further check, depending on the manager.
- Payment file protected: not in place.
- Two people pay out cash: not in place.
- Hours approved by supervisor: set out but not yet working in practice.
- Claims approved by a manager: only in some areas, cases or periods.
- Broker invoices against attendance: not in place.
- Most people in sensitive roles take block leave, with someone else doing their work. Concerns raised fairly: not in place. Support for financial pressure: not in place. No conflicting duties when covering: set out but not yet working in practice. No single point of knowledge: set out but not yet working in practice.
- Approval is sought only for large refunds or when staff are unsure. Returns received before credit: not in place. Claim evidence checked for AI: not in place. Refund patterns reviewed: only in some areas, cases or periods. Post-period reversals reviewed: only in some areas, cases or periods.
- Most changes are verified with the customer, but sales staff can still make them. Defined onboarding: not in place. Shared details flagged: not in place. Business customers verified: only in some areas, cases or periods.
- Documents are checked only if something looks wrong. Statements sent from the system: not in place. Limit and terms changes approved: set out but not yet working in practice. Most credit limits are approved by someone outside sales. Bureau and fraud database checks: only in some areas, cases or periods.
- Assessors rely on their own experience, without set indicators.

- The bank account appears on invoices, but there is no warning about changes.
- Non-standard prices approved: not in place.
- Agent sales verified: not in place.
- Vouchers controlled in the system: set out but not yet working in practice.
- Human review before a customer is blocked: only in some areas, cases or periods.
- Takings are reconciled occasionally, or only when there is a shortage.
- The stores team counts, and someone else glances at the results. How stock is recorded: not in place. Differences explained before adjusting: not in place. Stock is written off by the stores team without approval. Shrinkage tracked: set out but not yet working in practice.
- Devices wiped before disposal: only in some areas, cases or periods.
- Payment is confirmed in the bank for larger sales only.
- Changed collection instructions verified: only in some areas, cases or periods.
- Fuel purchases are not compared with vehicle use.
- Dispatch matched to orders: not in place.
- Organised theft assessed: not in place.
- Losses tracked and reported: set out but not yet working in practice.
- Email accounts are protected by passwords only.
- Payment changes received by email are acted on as received.
- Some staff check unusual requests, depending on their own judgement. Most changes are verified through the old details or another trusted route. Most executives with a public profile have agreed a verification method with their assistants and finance teams.
- Multi-factor authentication is offered, but customers can opt out.
- A compromise would be handled as it happens, without a set process. Affected people warned: not in place.
- Most resets need verification through a trusted route, such as the person's manager or a number on file.
- These systems are protected by passwords only.
- Access is limited for some systems only.
- Staff have been told about SIM swaps, but nothing has been changed.
- Assistant permissions limited: only in some areas, cases or periods.
- Staff guided on what not to share: not in place.
- Brand impersonation monitored and removed: not in place.
- Domain protected against spoofing: only in some areas, cases or periods.
- There is no plan; each case would be handled from scratch.

| ID | OBJECTIVE | RECOMMENDED DESIGN | ASSESSED | OWNER / OVERSIGHT | FREQUENCY | EFFECTIVENESS TEST |
|---|---|---|---|---|---|---|
| CI-FS-D3-10<br>D3-C-04<br>90 days | **Stop the scheme where staff do not know or understand what is expected.** | 1. Training on joining: the answer to "Do all employees receive fraud and ethics training when they join?" is yes, across everything it should cover. | STATE 1 | HR lead or ethics officer<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join? |
| CI-FS-D3-11<br>D3-N-02<br>90 days | **Stop the scheme where donations or sponsorships channel bribes.** | 1. Recipients checked for links: the answer to "Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed?" is yes, across everything it should cover. | STATE 2 | CSI or sustainability lead<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed? |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

| ID | OBJECTIVE | RECOMMENDED DESIGN | ASSESSED | OVERSIGHT | FREQUENCY | TEST |
|---|---|---|---|---|---|---|
| CI-FS-D4-01<br>D4-O-01<br>60 days | **Stop the scheme where a fictitious supplier is created and paid.** | 1. New supplier process: Every new supplier goes through a defined process, with set checks and an approval, before it can be paid. 2. Directors compared with staff: the answer to "Do you compare supplier directors, owners, addresses or bank accounts with your employee records?" is yes, across everything it should cover. 3. Dormant suppliers deactivated: the answer to "Are suppliers that have not been used for a set period deactivated?" is yes, across everything it should cover. 4. Suppliers re-checked: the answer to "Are existing suppliers re-checked periodically, not only when they are first added?" is yes, across everything it should cover. 5. Directors identified: Directors and owners, including those behind holding companies, are identified for every new supplier from an independent source. | STATE 3 | Procurement or creditors manager<br>The board or its audit committee | Every new supplier, customer or employee before activation | Management's own records show, for every case in the period: every new supplier goes through a defined process, with set checks and an approval, before it can be paid. |
| CI-FS-D4-02<br>D4-B-12<br>30 days | **Stop the scheme where supplier payments are diverted through changed bank details.** | 1. Familiar caller still verified: The procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why. 2. Change confirmed with supplier: Every change is confirmed with the supplier using contact details already on file before it takes effect. | STATE 4 | Creditors manager<br>The board or its audit committee | Every change to banking details, before the next payment | Management's own records show, for every case in the period: the procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why. |
| CI-FS-D4-03<br>D4-O-08<br>60 days | **Stop the scheme where a supplier is set up with an account it does not own.** | 1. Bank account verified: Every new supplier's account is verified through a bank or third-party service before the first payment. | STATE 5 | Procurement or creditors manager<br>The board or its audit committee | Every new supplier, customer or employee before activation | Management's own records show, for every case in the period: every new supplier's account is verified through a bank or third-party service before the first payment. |
| CI-FS-D4-04<br>D4-A-07<br>30 days | **Stop the scheme where one person can order and approve payment.** | 1. Orderer is not payment approver: The duties are always separated, or any exception is approved and recorded. | STATE 6 | Head of procurement or CFO<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: the duties are always separated, or any exception is approved and recorded. |

| ID | Objective | Recommended design | Assessed | Oversight | Frequency | Test |
|---|---|---|---|---|---|---|
| CI-FS-D4-05<br>D4-V-01<br>30 days | **Stop the scheme where invoices are paid for goods or services not received or not agreed.** | 1. Three-way match: Every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first. 2. Quantities checked: the answer to "Are delivered quantities checked against the delivery note and the order?" is yes, across everything it should cover. 3. Services confirmed: the answer to "For services, does the person receiving the service confirm it was delivered before payment?" is yes, across everything it should cover. 4. Approved order before commitment: Every purchase is approved by someone with the authority to do so before the organisation commits, and the approval is recorded. 5. Receipt recorded before payment: Receipt is always recorded before the related invoice is paid. | STATE 7 | Creditors manager or financial controller<br>The board or its audit committee | Every payment run | Management's own records show, for every case in the period: every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first. |
| CI-FS-D4-06<br>D4-T-13<br>60 days | **Stop the scheme where an outsourced provider misuses its access.** | 1. Provider access limited: Every provider's access is limited to what the service needs, logged and reviewed at least once a year. | STATE 8 | Head of procurement, with the business owner of each relationship<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: every provider's access is limited to what the service needs, logged and reviewed at least once a year. |
| CI-FS-D4-07<br>D4-V-06<br>90 days | **Stop the scheme where supplier payments are released without two approvals.** | 1. Two approvers on banking platform: The banking platform requires two separate people to approve every supplier payment. | STATE 9 | Creditors manager or financial controller<br>The board or its audit committee | Every payment run | Management's own records show, for every case in the period: the banking platform requires two separate people to approve every supplier payment. |
| CI-FS-D4-08<br>D4-C-06<br>90 days | **Stop the scheme where a tender is manipulated or purchases are split.** | 1. Evaluation against set criteria: Every competitive purchase is evaluated by more than one person against criteria set before bids are received, and scores are recorded. 2. Quote and tender thresholds: the answer to "Are there set amounts above which multiple quotes or a formal tender are required?" is yes, across everything it should cover. | STATE 10 | Head of procurement or bid committee secretary<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: every competitive purchase is evaluated by more than one person against criteria set before bids are received, and scores are recorded. |
| CI-FS-D4-09<br>D4-X-01<br>90 days | **Stop the scheme where buyers take kickbacks.** | 1. Annual interest declarations: Everyone involved in buying declares interests each year and when circumstances change, and declarations are kept on record. | STATE 11 | Compliance lead or HR<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: everyone involved in buying declares interests each year and when circumstances change, and declarations are kept on record. |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

| ID | OBJECTIVE | RECOMMENDED DESIGN | ASSESSED | OVERSIGHT | FREQUENCY | TEST |
|---|---|---|---|---|---|---|
| CI-FS-D4-10<br>D4-Q-04<br>90 days | **Stop the scheme where purchase cards or petty cash are misused.** | 1. Independent reconciliation: the answer to "Are statements reconciled and reviewed by someone other than the cardholder?" is yes, across everything it should cover. | STATE 12 | Financial controller<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Are statements reconciled and reviewed by someone other than the cardholder? |
| CI-FS-D4-11<br>D4-T-03<br>90 days | **Stop the scheme where intermediaries pay bribes or inflate fees.** | 1. Intermediaries vetted: the answer to "Are intermediaries vetted before appointment, including who owns them and their reputation?" is yes, across everything it should cover. | STATE 13 | Head of procurement, with the business owner of each relationship<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Are intermediaries vetted before appointment, including who owns them and their reputation? |
| CI-FS-D4-12<br>D4-V-15<br>90 days | **Stop the scheme where procurement anomalies are never noticed.** | 1. Senior review of supplier payments: the answer to "Does someone senior review a list of supplier payments at least once a month?" is yes, across everything it should cover. 2. Data reviewed for unusual patterns: the answer to "Does anyone regularly review procurement and supplier payment data for unusual patterns?" is yes, across everything it should cover. 3. Split orders monitored: the answer to "Do you monitor for several smaller orders to the same supplier that together exceed an approval limit?" is yes, across everything it should cover. 4. Independent review of procurement: the answer to "Has internal audit or an external reviewer examined procurement in the last two years?" is yes, across everything it should cover. | STATE 14 | Creditors manager or financial controller<br>The board or its audit committee | Every payment run | Management's own records show that every case in the period passes this test: Does someone senior review a list of supplier payments at least once a month? |
| CI-FS-D4-13<br>D4-K-04<br>90 days | **Stop the scheme where variations inflate the agreed value.** | 1. Variations approved first: the answer to "Must changes to agreed work, such as variations, extensions or extra scope, be approved before the work goes ahead, whether or not there is a written contract?" is yes, across everything it should cover. 2. Contract register: the answer to "Is there a register of all active supplier contracts?" is yes, across everything it should cover. 3. Large variations escalated: the answer to "Are variations above a set percentage of the original value approved at a higher level?" is yes, across everything it should cover. 4. Written supplier contracts: the answer to "Does the organisation sign written contracts with suppliers for ongoing or significant work?" is yes, across everything it should cover. | STATE 15 | Procurement or the finance manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Must changes to agreed work, such as variations, extensions or extra scope, be approved before the work goes ahead, whether or not there is a written contract? |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

| ID | OBJECTIVE | RECOMMENDED DESIGN | ASSESSED | OVERSIGHT | FREQUENCY | TEST |
|---|---|---|---|---|---|---|
| CI-FS-D5-01<br>D5-M-05<br>30 days | **Stop the scheme where salaries are redirected through a fake bank change.** | 1. Bank changes confirmed with employee: Every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect. | **STATE 16** | Payroll manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect. |
| CI-FS-D5-02<br>D5-P-01<br>60 days | **Stop the scheme where ghost employees are paid.** | 1. Payroll reviewed by another person: Every payroll run is reviewed before payment by someone who did not prepare it, and the review is recorded. 2. Headcount verification done: the answer to "Has the organisation matched the people on payroll to real employees, through a headcount or verification exercise, in the last two years?" is yes, across everything it should cover. 3. Independent review of payroll: the answer to "Has internal audit or an external reviewer examined payroll in the last two years?" is yes, across everything it should cover. | **STATE 17** | Payroll manager or financial controller<br>The board or its audit committee | Every pay run | Management's own records show, for every case in the period: every payroll run is reviewed before payment by someone who did not prepare it, and the review is recorded. |
| CI-FS-D5-03<br>D5-T-03<br>60 days | **Stop the scheme where leavers stay on the payroll.** | 1. Leavers removed before next run: Every leaver is confirmed as removed before the next pay run, using the HR leaver list. | **STATE 18** | HR manager<br>The board or its audit committee | Every leaver, before the next pay run | Management's own records show, for every case in the period: every leaver is confirmed as removed before the next pay run, using the HR leaver list. |
| CI-FS-D5-04<br>D5-R-03<br>60 days | **Stop the scheme where a false identity enters at hiring.** | 1. Identity verified: Every new employee's identity is verified against Home Affairs records, for example through a verification service, before they start. 2. Qualifications verified: Every qualification relied on for an appointment is verified with the issuing institution or through SAQA before the offer is final. | **STATE 19** | HR or recruitment manager<br>The board or its audit committee | Every appointment | Management's own records show, for every case in the period: every new employee's identity is verified against Home Affairs records, for example through a verification service, before they start. |
| CI-FS-D5-05<br>D5-R-13<br>60 days | **Stop the scheme where a stand-in or deepfake candidate is appointed.** | 1. Remote appointee identity confirmed: Every remote appointee is confirmed through an in-person meeting or an identity check designed to resist replayed and injected video before access and pay are set up, and failed checks are reviewed by a person. | **STATE 20** | HR or recruitment manager<br>The board or its audit committee | Every appointment | Management's own records show, for every case in the period: every remote appointee is confirmed through an in-person meeting or an identity check designed to resist replayed and injected video before access and pay are set up, and failed checks are reviewed by a person. |

| ID | Objective | Recommended design | Assessed | Oversight | Frequency | Test |
|---|---|---|---|---|---|---|
| CI-FS-D5-07<br>D5-P-07<br>90 days | **Stop the scheme where the payroll payment file is altered after approval.** | 1. Payment file protected: the answer to "Is the payroll payment file protected so that a change between approval and upload to the bank would be prevented or detected, for example through a secure bank connection or a file check that the preparer cannot regenerate?" is yes, across everything it should cover. | STATE 21 | Payroll manager or financial controller<br>The board or its audit committee | Every pay run | Management's own records show that every case in the period passes this test: Is the payroll payment file protected so that a change between approval and upload to the bank would be prevented or detected, for example through a secure bank connection or a file check that the preparer cannot regenerate? |
| CI-FS-D5-08<br>D5-C-01<br>90 days | **Stop the scheme where cash wages are stolen or paid to ghosts.** | 1. Two people pay out cash: the answer to "Are cash wages paid out by at least two people together?" is yes, across everything it should cover. | STATE 22 | Financial controller<br>The board or its audit committee | Every shift or banking cycle | Management's own records show that every case in the period passes this test: Are cash wages paid out by at least two people together? |
| CI-FS-D5-09<br>D5-L-05<br>90 days | **Stop the scheme where hours and overtime are inflated.** | 1. Hours approved by supervisor: the answer to "Are hours approved by a supervisor before they are paid?" is yes, across everything it should cover. | STATE 23 | HR or payroll manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Are hours approved by a supervisor before they are paid? |
| CI-FS-D5-10<br>D5-E-02<br>90 days | **Stop the scheme where expenses and advances are abused.** | 1. Claims approved by a manager: the answer to "Is each claim approved by a manager other than the claimant?" is yes, across everything it should cover. | STATE 24 | Financial controller<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Is each claim approved by a manager other than the claimant? |
| CI-FS-D5-11<br>D5-B-02<br>90 days | **Stop the scheme where labour brokers invoice for workers who were not there.** | 1. Broker invoices against attendance: the answer to "Are labour broker invoices checked against your own attendance records?" is yes, across everything it should cover. | STATE 25 | Operations manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Are labour broker invoices checked against your own attendance records? |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

| ID | OBJECTIVE | RECOMMENDED DESIGN | ASSESSED | OVERSIGHT | FREQUENCY | TEST |
|---|---|---|---|---|---|---|
| CI-FS-D5-12<br>D5-K-01<br>90 days | **Stop the scheme where an insider in a high-risk role works unchecked.** | 1. Block leave required: Everyone in a sensitive role takes a block of consecutive leave each year, with their work done by someone else, and exceptions are approved. 2. Concerns raised fairly: the answer to "Is there a defined way for managers to raise and escalate concerns about an employee's behaviour, confidentially and without making accusations?" is yes, across everything it should cover. 3. Support for financial pressure: the answer to "Does the organisation offer support to employees in financial difficulty, such as financial wellness or employee assistance programmes?" is yes, across everything it should cover. 4. No conflicting duties when covering: the answer to "Are people in high-risk roles, such as those who can move money or change master data, kept from holding conflicting duties, even temporarily when they cover for colleagues?" is yes, across everything it should cover. 5. No single point of knowledge: the answer to "Is there enough depth in high-risk roles that no single person is the only one who understands or can perform a critical process?" is yes, across everything it should cover. 6. High-risk roles identified: A maintained list of high-risk roles covers the whole organisation, including roles that can move money, change master data or manage system access. | STATE 26 | HR manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: everyone in a sensitive role takes a block of consecutive leave each year, with their work done by someone else, and exceptions are approved. |
| CI-FS-D7-01<br>D7-R-01<br>60 days | **Stop the scheme where refunds are stolen.** | 1. Refunds approved independently: Every refund and credit note is approved by someone other than the person who processes it. 2. Returns received before credit: the answer to "Is every return matched to the goods physically coming back into stock before a credit is issued?" is yes, across everything it should cover. 3. Claim evidence checked for AI: the answer to "Are photographs and documents supporting refund or return requests checked for manipulation, such as AI-generated images of damage?" is yes, across everything it should cover. 4. Refund patterns reviewed: the answer to "Are refunds and credit notes reviewed for patterns, such as the same employee or customer, or amounts just below approval limits?" is yes, across everything it should cover. 5. Post-period reversals reviewed: the answer to "Are credit notes and reversals raised after a period end reviewed, so sales reversed once targets were met are noticed?" is yes, across everything it should cover. | STATE 27 | Customer service or finance manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: every refund and credit note is approved by someone other than the person who processes it. |

| ID | OBJECTIVE | RECOMMENDED DESIGN | ASSESSED | OVERSIGHT | FREQUENCY | TEST |
|---|---|---|---|---|---|---|
| CI-FS-D7-02<br>D7-O-04<br>60 days | **Stop the scheme where customer details are changed to divert money or goods.** | 1. Customer detail changes verified: Every change to refund accounts, addresses and contact numbers is verified with the customer through known details and made by someone outside sales. 2. Defined onboarding: the answer to "Is there a defined process for taking on a new customer or opening an account before goods, services or credit are provided?" is yes, across everything it should cover. 3. Shared details flagged: the answer to "Does the system or a review flag customers who share details, such as ID numbers, phone numbers, addresses or bank accounts, with other customers or with employees?" is yes, across everything it should cover. 4. Business customers verified: the answer to "Are business customers checked as real and registered, for example through CIPC, and is it confirmed who may act for them?" is yes, across everything it should cover. | STATE 28 | Customer onboarding or operations manager<br>The board or its audit committee | Every new supplier, customer or employee before activation | Management's own records show, for every case in the period: every change to refund accounts, addresses and contact numbers is verified with the customer through known details and made by someone outside sales. |
| CI-FS-D7-03<br>D7-C-02<br>60 days | **Stop the scheme where credit is obtained with fabricated documents.** | 1. Application documents verified: The key information in every application is verified with the source, such as the employer, the bank or a verification service, before credit is approved. 2. Statements sent from the system: the answer to "Are customer statements sent directly from the system, so that an employee cannot hide a diverted payment from the customer?" is yes, across everything it should cover. 3. Limit and terms changes approved: the answer to "Are changes to credit limits and payment terms approved and logged?" is yes, across everything it should cover. 4. Credit approved independently: Every credit limit is approved by someone other than the salesperson, within set authority levels. 5. Bureau and fraud database checks: the answer to "Are applicants checked with a credit bureau and a fraud database, such as the Southern African Fraud Prevention Service, before credit is approved?" is yes, across everything it should cover. 6. Early defaults investigated: the answer to "Are accounts that miss their first payments investigated as possible application fraud, not treated only as bad debt?" is yes, across everything it should cover. | STATE 29 | Credit manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: the key information in every application is verified with the source, such as the employer, the bank or a verification service, before credit is approved. |
| CI-FS-D7-05<br>D7-K-02<br>60 days | **Stop the scheme where claims are fabricated or inflated.** | 1. Fraud indicators screened: Every claim is screened against defined indicators, such as early claims, repeat claimants and recurring service providers, and flagged claims are referred. | STATE 30 | Claims manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: every claim is screened against defined indicators, such as early claims, repeat claimants and recurring service providers, and flagged claims are referred. |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

| ID | OBJECTIVE | RECOMMENDED DESIGN | ASSESSED | OVERSIGHT | FREQUENCY | TEST |
|---|---|---|---|---|---|---|
| CI-FS-D7-09<br>D7-B-01<br>90 days | **Stop the scheme where sales are not billed or receipts are diverted.** | 1. Everything supplied is billed: Every delivery or service is matched to an invoice, and unbilled items are investigated. | STATE 31 | Billing or debtors manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: every delivery or service is matched to an invoice, and unbilled items are investigated. |
| CI-FS-D7-10<br>D7-B-04<br>90 days | **Stop the scheme where customers pay fraudsters impersonating the organisation.** | 1. Customers warned about payment redirection: Every invoice and statement shows the bank account and states that it will never change by email or message alone. | STATE 32 | Billing or debtors manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: every invoice and statement shows the bank account and states that it will never change by email or message alone. |
| CI-FS-D7-11<br>D7-P-02<br>90 days | **Stop the scheme where prices are overridden or side deals made.** | 1. Non-standard prices approved: the answer to "Are prices or discounts outside the standard approved by someone other than the salesperson, within set limits?" is yes, across everything it should cover. | STATE 33 | Sales or commercial manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Are prices or discounts outside the standard approved by someone other than the salesperson, within set limits? |
| CI-FS-D7-12<br>D7-H-01<br>90 days | **Stop the scheme where agents report fictitious sales.** | 1. Agent sales verified: the answer to "Are sales reported by agents or resellers checked against real customer activity, such as payments received or goods delivered, before commission is paid?" is yes, across everything it should cover. | STATE 34 | Channel or sales manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Are sales reported by agents or resellers checked against real customer activity, such as payments received or goods delivered, before commission is paid? |
| CI-FS-D7-13<br>D7-L-02<br>90 days | **Stop the scheme where vouchers and loyalty points are abused.** | 1. Vouchers controlled in the system: the answer to "Are vouchers, gift cards and promotion codes issued and redeemed through a system that prevents duplicates and records who issued them?" is yes, across everything it should cover. | STATE 35 | Marketing manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Are vouchers, gift cards and promotion codes issued and redeemed through a system that prevents duplicates and records who issued them? |
| CI-FS-D7-14<br>D7-M-08<br>90 days | **Stop the scheme where customers are wrongly blocked on a fraud flag.** | 1. Human review before a customer is blocked: the answer to "Before a customer's account is blocked or a claim is declined because of a fraud flag, does a person review the decision?" is yes, across everything it should cover. | STATE 36 | Fraud or risk lead<br>The board or its audit committee | Monthly | Management's own records show that every case in the period passes this test: Before a customer's account is blocked or a claim is declined because of a fraud flag, does a person review the decision? |

| ID | OBJECTIVE | RECOMMENDED DESIGN | ASSESSED | OVERSIGHT | FREQUENCY | TEST |
|---|---|---|---|---|---|---|
| CI-FS-D8-01<br>D8-C-03<br>60 days | **Stop the scheme where cash takings are stolen.** | 1. Daily reconciliation: Takings at every cash point are reconciled to sales records daily, and every shortage and surplus is investigated. | STATE 37 | Store, branch or cash office manager<br>The board or its audit committee | Every shift or banking cycle | Management's own records show, for every case in the period: takings at every cash point are reconciled to sales records daily, and every shortage and surplus is investigated. |
| CI-FS-D8-02<br>D8-K-02<br>60 days | **Stop the scheme where stock is stolen and hidden in the counts.** | 1. Independent blind counts: Every count is carried out or observed by people independent of the stores team, counting without sight of system quantities. 2. How stock is recorded: the answer to "How is stock recorded?" is yes, across everything it should cover. 3. Differences explained before adjusting: the answer to "Are count differences investigated and explained before the records are adjusted?" is yes, across everything it should cover. 4. Write-offs approved and supervised: Every write-off is approved at a senior level, and the goods are destroyed or disposed of under independent supervision, with a record. 5. Shrinkage tracked: the answer to "Are shrinkage and loss rates tracked by site, product and shift, and investigated when they rise?" is yes, across everything it should cover. 6. Full counts: the answer to "Is all stock counted at least once a year, with high-value or fast-moving items counted more often?" is yes, across everything it should cover. | STATE 38 | Financial controller<br>The board or its audit committee | Every count cycle | Management's own records show, for every case in the period: every count is carried out or observed by people independent of the stores team, counting without sight of system quantities. |
| CI-FS-D8-04<br>D8-A-08<br>90 days | **Stop the scheme where data leaves on disposed or reissued devices.** | 1. Devices wiped before disposal: the answer to "Are laptops, phones and other devices wiped of the organisation's data before they are disposed of, sold, reissued or returned?" is yes, across everything it should cover. | STATE 39 | Asset or facilities manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Are laptops, phones and other devices wiped of the organisation's data before they are disposed of, sold, reissued or returned? |
| CI-FS-D8-05<br>D8-D-04<br>90 days | **Stop the scheme where assets or scrap are sold off cheaply or without payment.** | 1. Paid before collection: Payment is confirmed on the organisation's own bank statement before any goods are collected. | STATE 40 | Financial controller, with the asset owner<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: payment is confirmed on the organisation's own bank statement before any goods are collected. |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

| ID | OBJECTIVE | RECOMMENDED DESIGN | ASSESSED | OVERSIGHT | FREQUENCY | TEST |
|---|---|---|---|---|---|---|
| CI-FS-D8-06<br>D8-I-10<br>90 days | **Stop the scheme where goods are released to an impostor.** | 1. Changed collection instructions verified: the answer to "When an instruction to release or collect goods changes, such as a new delivery address or a different collector, is the change verified through known contact details, and is the collector's identity checked at release?" is yes, across everything it should cover. | STATE 41 | Warehouse or stores manager<br>The board or its audit committee | Every count cycle | Management's own records show that every case in the period passes this test: When an instruction to release or collect goods changes, such as a new delivery address or a different collector, is the change verified through known contact details, and is the collector's identity checked at release? |
| CI-FS-D8-07<br>D8-F-03<br>90 days | **Stop the scheme where fuel and fleet are misused.** | 1. Fuel matched to distance: Every vehicle's fuel purchases are compared with tracking data, distance travelled and expected consumption, and exceptions are investigated. | STATE 42 | Fleet manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: every vehicle's fuel purchases are compared with tracking data, distance travelled and expected consumption, and exceptions are investigated. |
| CI-FS-D8-08<br>D8-T-01<br>90 days | **Stop the scheme where goods go missing in transit.** | 1. Dispatch matched to orders: the answer to "Is every dispatch matched to an approved order before the goods leave?" is yes, across everything it should cover. | STATE 43 | Logistics manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Is every dispatch matched to an approved order before the goods leave? |
| CI-FS-D8-09<br>D8-H-01<br>90 days | **Stop the scheme where high-value materials are stolen by organised groups.** | 1. Organised theft assessed: the answer to "Is the risk of organised theft, such as theft of copper, cable, metals or fuel, assessed together with the security provider?" is yes, across everything it should cover. | STATE 44 | Security manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Is the risk of organised theft, such as theft of copper, cable, metals or fuel, assessed together with the security provider? |
| CI-FS-D8-11<br>D8-M-01<br>90 days | **Stop the scheme where losses are never tracked.** | 1. Losses tracked and reported: the answer to "Are losses of cash, stock and assets tracked over time and by location, and reported to management?" is yes, across everything it should cover. | STATE 45 | Financial controller or internal audit<br>The board or its audit committee | Monthly | Management's own records show that every case in the period passes this test: Are losses of cash, stock and assets tracked over time and by location, and reported to management? |
| CI-FS-D9-01<br>D9-E-01<br>30 days | **Stop the scheme where an email account is taken over.** | 1. Multi-factor on all email: Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. | STATE 46 | Head of IT or IT provider<br>The board or its audit committee | Continuous, with monthly review | Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. |

| ID | OBJECTIVE | RECOMMENDED DESIGN | ASSESSED | OVERSIGHT | FREQUENCY | TEST |
|---|---|---|---|---|---|---|
| CI-FS-D9-02<br>D9-E-05<br>30 days | **Stop the scheme where a payment instruction received by email is acted on.** | 1. Email never enough on its own: An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it. | STATE 47 | Head of IT or IT provider<br>The board or its audit committee | Continuous, with monthly review | Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it. |
| CI-FS-D9-03<br>D9-I-01<br>60 days | **Stop the scheme where a cloned voice or video instruction is obeyed.** | 1. Verification for calls, voice notes and video: An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it. 2. Changes to call-back details verified: Every change to a phone number or email used for verification is confirmed through the previous details or another trusted route before it is used. 3. Executives and their teams prepared: Every executive with a public voice or face has been briefed and has an agreed verification method that their assistants and finance teams use. | STATE 48 | CFO and head of IT together<br>The board or its audit committee | Every payment or change instruction received electronically | Management's own records show, for every case in the period: an agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it. |
| CI-FS-D9-04<br>D9-H-01<br>60 days | **Stop the scheme where customer accounts are taken over.** | 1. Customer logins protected: Customer logins are protected with multi-factor authentication, device recognition and limits on repeated failed attempts. | STATE 49 | Head of digital channels<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: customer logins are protected with multi-factor authentication, device recognition and limits on repeated failed attempts. |
| CI-FS-D9-05<br>D9-P-04<br>60 days | **Stop the scheme where a security compromise is not notified.** | 1. Compromises reported as POPIA requires: A procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly. 2. Affected people warned: the answer to "When data is leaked, are affected people warned about follow-up fraud, such as phishing that uses their real details?" is yes, across everything it should cover. | STATE 50 | Head of IT or information security<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly. |
| CI-FS-D9-06<br>D9-A-05<br>90 days | **Stop the scheme where a help desk reset hands an attacker access.** | 1. Help desk resets verified: Every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel. | STATE 51 | Head of IT or IT provider<br>The board or its audit committee | Every joiner, mover and leaver, and quarterly review | Management's own records show, for every case in the period: every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel. |

| ID | OBJECTIVE | RECOMMENDED DESIGN | ASSESSED | OVERSIGHT | FREQUENCY | TEST |
|---|---|---|---|---|---|---|
| CI-FS-D9-07<br>D9-A-01<br>90 days | **Stop the scheme where systems that move money are accessed without strong sign-in.** | 1. Multi-factor on critical systems: It is required for remote access, cloud systems, the banking platform and every system that can move money or change master data. | STATE 52 | Head of IT or IT provider<br>The board or its audit committee | Every joiner, mover and leaver, and quarterly review | Management's own records show, for every case in the period: it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data. |
| CI-FS-D9-08<br>D9-P-01<br>90 days | **Stop the scheme where personal information is over-exposed or kept too long.** | 1. Access to personal information limited: In every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged. | STATE 53 | Information officer (POPIA)<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged. |
| CI-FS-D9-09<br>D9-M-01<br>90 days | **Stop the scheme where a SIM swap defeats one-time PIN approvals.** | 1. Approval numbers protected: Every number used to approve payments or reset access has a network SIM-swap lock or has been replaced by an authenticator app. | STATE 54 | Head of IT, with finance<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: every number used to approve payments or reset access has a network SIM-swap lock or has been replaced by an authenticator app. |
| CI-FS-D9-10<br>D9-G-02<br>90 days | **Stop the scheme where an AI assistant is manipulated by hidden instructions.** | 1. Assistant permissions limited: the answer to "Are the permissions of AI assistants limited to what each task needs, so that they cannot make payments, change records or send messages without a person's approval?" is yes, across everything it should cover. | STATE 55 | Head of IT or the person responsible for AI tools<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Are the permissions of AI assistants limited to what each task needs, so that they cannot make payments, change records or send messages without a person's approval? |
| CI-FS-D9-11<br>D9-O-02<br>90 days | **Stop the scheme where the organisation's own information helps attackers.** | 1. Staff guided on what not to share: the answer to "Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling?" is yes, across everything it should cover. | STATE 56 | Communications or marketing manager<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show that every case in the period passes this test: Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling? |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

| ID | OBJECTIVE | RECOMMENDED DESIGN | ASSESSED | OVERSIGHT | FREQUENCY | TEST |
|---|---|---|---|---|---|---|
| CI-FS-D9-13<br>D9-I-05<br>90 days | **Stop the scheme where the organisation is impersonated to defraud others.** | 1. Brand impersonation monitored and removed: the answer to "Does the organisation watch for fake websites, social media accounts and adverts that impersonate it, and have them taken down?" is yes, across everything it should cover. | STATE 57 | CFO and head of IT together<br>The board or its audit committee | Every payment or change instruction received electronically | Management's own records show that every case in the period passes this test: Does the organisation watch for fake websites, social media accounts and adverts that impersonate it, and have them taken down? |
| CI-FS-D9-14<br>D9-E-02<br>90 days | **Stop the scheme where spoofed email in the organisation's name deceives staff, suppliers or customers.** | 1. Domain protected against spoofing: the answer to "Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject?" is yes, across everything it should cover. | STATE 58 | Head of IT or IT provider<br>The board or its audit committee | Continuous, with monthly review | Management's own records show that every case in the period passes this test: Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject? |
| CI-FS-D9-12<br>D9-R-02<br>90 days | **Stop the scheme where a compromise is not contained quickly.** | 1. Compromise playbook: A written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles. | STATE 59 | Head of IT or information security<br>The board or its audit committee | As each case arises, with a monthly review by the process owner | Management's own records show, for every case in the period: a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles. |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# Evidence requirement register

What management should be able to produce for each recommended control. No evidence has been requested, received or examined.

## Supplier and payment integrity

| CONTROL | EVIDENCE REQUIRED | WHAT IT SHOULD PROVE | MINIMUM ACCEPTABLE CHARACTERISTIC | OWNER / RECENCY |
|---|---|---|---|---|
| CI-FS-D4-01 | **The onboarding procedure, completed onboarding files for a sample of new suppliers, exception reports.** | That every new supplier goes through a defined process, with set checks and an approval, before it can be paid | Covers every case in the period, not a selection | Procurement or creditors manager<br>Every new supplier, customer or employee before activation |
| | **CIPC search results on file, the onboarding form, a sample of supplier records.** | That directors and owners, including those behind holding companies, are identified for every new supplier from an independent source | Covers every case in the period, not a selection | Procurement or creditors manager<br>Every new supplier, customer or employee before activation |
| CI-FS-D4-02 | **The procedure wording, training material on cloned voices, simulation or test results.** | That the procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why | Covers every case in the period, not a selection | Creditors manager<br>Every change to banking details, before the next payment |
| | **Change records with call-back notes, the procedure, a sample of recent changes.** | That every change is confirmed with the supplier using contact details already on file before it takes effect | Covers every case in the period, not a selection | Creditors manager<br>Every change to banking details, before the next payment |
| CI-FS-D4-03 | **Account verification results, for example through a bank's account verification service, and the onboarding checklist.** | That every new supplier's account is verified through a bank or third-party service before the first payment | Covers every case in the period, not a selection | Procurement or creditors manager<br>Every new supplier, customer or employee before activation |
| CI-FS-D4-04 | **The delegation of authority, system access lists, a sample of orders and the related payment approvals.** | That the duties are always separated, or any exception is approved and recorded | Covers every case in the period, not a selection | Head of procurement or CFO<br>As each case arises, with a monthly review by the process owner |
| CI-FS-D4-05 | **Payment files showing the order, receipt and invoice, exception reports.** | That every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first | Covers every case in the period, not a selection | Creditors manager or financial controller<br>Every payment run |
| | **Purchase orders or approval records dated before the invoice, for a sample of recent purchases.** | That every purchase is approved by someone with the authority to do so before the organisation commits, and the approval is recorded | Covers every case in the period, not a selection | Procurement manager<br>Every payment run |
| | **Goods received notes, the receiving system, a sample matched to payments.** | That receipt is always recorded before the related invoice is paid | Covers every case in the period, not a selection | Stores or operations manager<br>Every payment run |
| CI-FS-D4-06 | **The list of providers with access, access settings, the last access review.** | That every provider's access is limited to what the service needs, logged and reviewed at least once a year | Covers every case in the period, not a selection | Head of procurement, with the business owner of each relationship<br>As each case arises, with a monthly review by the process owner |
| CI-FS-D4-07 | **Banking platform user and approval settings, a sample of payment approvals.** | That the banking platform requires two separate people to approve every supplier payment | Covers every case in the period, not a selection | Creditors manager or financial controller<br>Every payment run |
| CI-FS-D4-08 | **Evaluation scoresheets, the request for quotation or tender with its criteria, committee minutes.** | That every competitive purchase is evaluated by more than one person against criteria set before bids are received, and scores are recorded | Covers every case in the period, not a selection | Head of procurement or bid committee secretary<br>As each case arises, with a monthly review by the process owner |
| CI-FS-D4-09 | **The declarations register for buying staff, completion records, follow-up of missing declarations.** | That everyone involved in buying declares interests each year and when circumstances change, and declarations are kept on record | Covers every case in the period, not a selection | Compliance lead or HR<br>As each case arises, with a monthly review by the process owner |

| CONTROL | EVIDENCE REQUIRED | WHAT IT SHOULD PROVE | MINIMUM ACCEPTABLE CHARACTERISTIC | OWNER / RECENCY |
|---|---|---|---|---|
| CI-FS-D5-12 | **The leave policy, leave records for sensitive roles, approved exceptions.** | That everyone in a sensitive role takes a block of consecutive leave each year, with their work done by someone else, and exceptions are approved | Covers every case in the period, not a selection | HR manager<br>As each case arises, with a monthly review by the process owner |
| | **The list of high-risk roles and the date it was last reviewed.** | That a maintained list of high-risk roles covers the whole organisation, including roles that can move money, change master data or manage system access | Covers every case in the period, not a selection | HR manager, with the head of IT<br>As each case arises, with a monthly review by the process owner |
| CI-FS-D7-02 | **Change logs for customer records, verification notes, the list of people who can change details.** | That every change to refund accounts, addresses and contact numbers is verified with the customer through known details and made by someone outside sales | Covers every case in the period, not a selection | Customer onboarding or operations manager<br>Every new supplier, customer or employee before activation |
| CI-FS-D9-01 | **The email security report showing multi-factor status for every account, including shared mailboxes.** | That multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions | Covers every case in the period, not a selection | Head of IT or IT provider<br>Continuous, with monthly review |
| CI-FS-D9-02 | **The written rule, staff communication, call-back records for a sample of requests.** | That an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it | Covers every case in the period, not a selection | Head of IT or IT provider<br>Continuous, with monthly review |
| CI-FS-D9-03 | **The verification procedure, briefing records for executives, simulation results.** | That an agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it | Covers every case in the period, not a selection | CFO and head of IT together<br>Every payment or change instruction received electronically |
| | **Change records for supplier and executive contact details, how each change was confirmed.** | That every change to a phone number or email used for verification is confirmed through the previous details or another trusted route before it is used | Covers every case in the period, not a selection | CFO and head of IT together<br>Every payment or change instruction received electronically |
| | **Briefing records for executives, the agreed verification method, assistants' instructions.** | That every executive with a public voice or face has been briefed and has an agreed verification method that their assistants and finance teams use | Covers every case in the period, not a selection | CFO and head of IT together<br>Every payment or change instruction received electronically |
| CI-FS-D9-04 | **Customer authentication settings, lockout rules, takeover statistics.** | That customer logins are protected with multi-factor authentication, device recognition and limits on repeated failed attempts | Covers every case in the period, not a selection | Head of digital channels<br>As each case arises, with a monthly review by the process owner |
| CI-FS-D9-06 | **The help desk reset procedure, reset logs, social engineering test results.** | That every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel | Covers every case in the period, not a selection | Head of IT or IT provider<br>Every joiner, mover and leaver, and quarterly review |
| CI-FS-D9-07 | **Multi-factor coverage reports for remote access, cloud and banking systems.** | That it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data | Covers every case in the period, not a selection | Head of IT or IT provider<br>Every joiner, mover and leaver, and quarterly review |
| CI-FS-D9-08 | **Role-based access settings, export restrictions, access reviews.** | That in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged | Covers every case in the period, not a selection | Information officer (POPIA)<br>As each case arises, with a monthly review by the process owner |
| CI-FS-D9-09 | **The list of numbers used for approvals, SIM-swap protection confirmations, authenticator app rollout.** | That every number used to approve payments or reset access has a network SIM-swap lock or has been replaced by an authenticator app | Covers every case in the period, not a selection | Head of IT, with finance<br>As each case arises, with a monthly review by the process owner |

## Payroll integrity

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

| CONTROL | EVIDENCE REQUIRED | WHAT IT SHOULD PROVE | CHARACTERISTIC | OWNER / RECENCY |
|---|---|---|---|---|
| CI-FS-D5-01 | **Bank change records showing how each change was confirmed, the procedure.** | That every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect | Covers every case in the period, not a selection | Payroll manager<br>As each case arises, with a monthly review by the process owner |
| CI-FS-D5-02 | **Signed payroll review checklists, variance explanations, the approval trail.** | That every payroll run is reviewed before payment by someone who did not prepare it, and the review is recorded | Covers every case in the period, not a selection | Payroll manager or financial controller<br>Every pay run |
| CI-FS-D5-03 | **Leaver lists reconciled to payroll, the pay run checklist.** | That every leaver is confirmed as removed before the next pay run, using the HR leaver list | Covers every case in the period, not a selection | HR manager<br>Every leaver, before the next pay run |
| CI-FS-D5-04 | **Verification service results on employee files, the onboarding checklist.** | That every new employee's identity is verified against Home Affairs records, for example through a verification service, before they start | Covers every case in the period, not a selection | HR or recruitment manager<br>Every appointment |
| | **Verification results from institutions or SAQA, the recruitment checklist.** | That every qualification relied on for an appointment is verified with the issuing institution or through SAQA before the offer is final | Covers every case in the period, not a selection | HR or recruitment manager<br>Every appointment |
| CI-FS-D5-05 | **The remote hiring procedure, identity check results, records of in-person meetings.** | That every remote appointee is confirmed through an in-person meeting or an identity check designed to resist replayed and injected video before access and pay are set up, and failed checks are reviewed by a person | Covers every case in the period, not a selection | HR or recruitment manager<br>Every appointment |

## Detection and exception review

| CONTROL | EVIDENCE REQUIRED | WHAT IT SHOULD PROVE | MINIMUM ACCEPTABLE CHARACTERISTIC | OWNER / RECENCY |
|---|---|---|---|---|
| CI-FS-D7-01 | **A sample of refunds and credit notes with approvals, system workflow settings.** | That every refund and credit note is approved by someone other than the person who processes it | Covers every case in the period, not a selection | Customer service or finance manager<br>As each case arises, with a monthly review by the process owner |
| CI-FS-D7-03 | **Verification records for a sample of applications, the credit procedure.** | That the key information in every application is verified with the source, such as the employer, the bank or a verification service, before credit is approved | Covers every case in the period, not a selection | Credit manager<br>As each case arises, with a monthly review by the process owner |
| | **Credit approval records, the credit authority matrix, system access to change limits.** | That every credit limit is approved by someone other than the salesperson, within set authority levels | Covers every case in the period, not a selection | Credit manager<br>As each case arises, with a monthly review by the process owner |
| CI-FS-D7-05 | **The claims fraud indicator list, screening results, referrals to investigators.** | That every claim is screened against defined indicators, such as early claims, repeat claimants and recurring service providers, and flagged claims are referred | Covers every case in the period, not a selection | Claims manager<br>As each case arises, with a monthly review by the process owner |
| CI-FS-D7-09 | **Delivery-to-invoice matching reports, investigation of unbilled items.** | That every delivery or service is matched to an invoice, and unbilled items are investigated | Covers every case in the period, not a selection | Billing or debtors manager<br>As each case arises, with a monthly review by the process owner |
| CI-FS-D7-10 | **Invoice and statement templates, customer communications on payment safety.** | That every invoice and statement shows the bank account and states that it will never change by email or message alone | Covers every case in the period, not a selection | Billing or debtors manager<br>As each case arises, with a monthly review by the process owner |

## Stock and asset custody

| CONTROL | EVIDENCE REQUIRED | WHAT IT SHOULD PROVE | MINIMUM ACCEPTABLE CHARACTERISTIC | OWNER / RECENCY |
|---|---|---|---|---|
| CI-FS-D8-02 | **Count instructions, count sheets without system quantities, the names of counters and observers.** | That every count is carried out or observed by people independent of the stores team, counting without sight of system quantities | Covers every case in the period, not a selection | Financial controller<br>Every count cycle |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

| CONTROL | EVIDENCE REQUIRED | WHAT IT SHOULD PROVE | CHARACTERISTIC | OWNER / RECENCY |
|---|---|---|---|---|
| | **Approved write-off forms, disposal or destruction certificates, the write-off register.** | That every write-off is approved at a senior level, and the goods are destroyed or disposed of under independent supervision, with a record | Covers every case in the period, not a selection | Financial controller<br>Every count cycle |
| CI-FS-D8-05 | **Release records showing payment confirmed on the bank statement.** | That payment is confirmed on the organisation's own bank statement before any goods are collected | Covers every case in the period, not a selection | Financial controller, with the asset owner<br>As each case arises, with a monthly review by the process owner |
| CI-FS-D8-07 | **Fuel exception reports, tracking data comparisons, follow-up notes.** | That every vehicle's fuel purchases are compared with tracking data, distance travelled and expected consumption, and exceptions are investigated | Covers every case in the period, not a selection | Fleet manager<br>As each case arises, with a monthly review by the process owner |

## Incident response and evidence integrity

| CONTROL | EVIDENCE REQUIRED | WHAT IT SHOULD PROVE | MINIMUM ACCEPTABLE CHARACTERISTIC | OWNER / RECENCY |
|---|---|---|---|---|
| CI-FS-D9-05 | **The breach response procedure, notification templates, records of past notifications.** | That a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly | Covers every case in the period, not a selection | Head of IT or information security<br>As each case arises, with a monthly review by the process owner |
| CI-FS-D9-12 | **The incident plan for email compromise, its contact list, test or incident records.** | That a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles | Covers every case in the period, not a selection | Head of IT or information security<br>As each case arises, with a monthly review by the process owner |

## Cash custody

| CONTROL | EVIDENCE REQUIRED | WHAT IT SHOULD PROVE | MINIMUM ACCEPTABLE CHARACTERISTIC | OWNER / RECENCY |
|---|---|---|---|---|
| CI-FS-D8-01 | **Daily reconciliation sheets, the shortages and surpluses log, investigation notes.** | That takings at every cash point are reconciled to sales records daily, and every shortage and surplus is investigated | Covers every case in the period, not a selection | Store, branch or cash office manager<br>Every shift or banking cycle |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# 12-month action and assurance register

The full twelve-month programme. Not every row is initial implementation: later horizons operate each control through its required cycle and then review whether it is still effective. The work type on each row says which it is.

| HORIZON | WORK TYPE | ACTION | OWNER | COMPLETION CRITERION | EFFECTIVENESS MEASURE |
|---|---|---|---|---|---|
| **30 days** | Implement | Obtain the 7 outstanding answers (2 on controls that stop a scheme) from Risk and investigations, HR and payroll, Finance and Operations and sales and 1 other functions, and record any that cannot be answered as an open risk. | CEO or company secretary | The completed function packages. | Every outstanding answer is given or recorded as an open risk with a named owner. |
| **30 days** | Implement | Close the scheme where supplier payments are diverted through changed bank details: put in place familiar caller still verified and change confirmed with supplier. | Head of procurement or CFO | The procedure wording, training material on cloned voices, simulation or test results. Change records with call-back notes, the procedure, a sample of recent changes. | Management's own records show, for every case in the period: the procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why. |
| **30 days** | Implement | Close the scheme where one person can order and approve payment: put in place orderer is not payment approver. | Head of procurement or CFO | The delegation of authority, system access lists, a sample of orders and the related payment approvals. | Management's own records show, for every case in the period: the duties are always separated, or any exception is approved and recorded. |
| **30 days** | Implement | Close the scheme where invoices are paid for goods or services not received or not agreed: put in place three-way match, quantities checked, services confirmed and approved order before commitment. | Head of procurement or CFO | Payment files showing the order, receipt and invoice, exception reports. Purchase orders or approval records dated before the invoice, for a sample of recent purchases. Goods received notes, the receiving system, a sample matched to payments. | Management's own records show, for every case in the period: every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first. |
| **30 days** | Implement | Close the scheme where salaries are redirected through a fake bank change: put in place bank changes confirmed with employee. | HR or payroll manager | Bank change records showing how each change was confirmed, the procedure. | Management's own records show, for every case in the period: every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect. |
| **30 days** | Implement | Close the scheme where an email account is taken over: put in place multi-factor on all email. | Head of IT or IT provider | The email security report showing multi-factor status for every account, including shared mailboxes. | Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. |
| **30 days** | Implement | Close the scheme where a payment instruction received by email is acted on: put in place email never enough on its own. | Head of IT or IT provider | The written rule, staff communication, call-back records for a sample of requests. | Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it. |
| **60 days** | Implement | Close the scheme where a fictitious supplier is created and paid: put in place new supplier process, directors compared with staff, dormant suppliers deactivated and suppliers re-checked. | Head of procurement or CFO | The onboarding procedure, completed onboarding files for a sample of new suppliers, exception reports. CIPC search results on file, the onboarding form, a sample of supplier records. | Management's own records show, for every case in the period: every new supplier goes through a defined process, with set checks and an approval, before it can be paid. |
| **60 days** | Implement | Close the scheme where a supplier is set up with an account it does not own: put in place bank account verified. | Head of procurement or CFO | Account verification results, for example through a bank's account verification service, and the onboarding checklist. | Management's own records show, for every case in the period: every new supplier's account is verified through a bank or third-party service before the first payment. |

| | | | | | |
|---|---|---|---|---|---|
| **60 days** | Implement | Close the scheme where an outsourced provider misuses its access: put in place provider access limited. | Head of procurement or CFO | The list of providers with access, access settings, the last access review. | Management's own records show, for every case in the period: every provider's access is limited to what the service needs, logged and reviewed at least once a year. |
| **60 days** | Implement | Close the scheme where ghost employees are paid: put in place payroll reviewed by another person, headcount verification done and independent review of payroll. | HR or payroll manager | Signed payroll review checklists, variance explanations, the approval trail. | Management's own records show, for every case in the period: every payroll run is reviewed before payment by someone who did not prepare it, and the review is recorded. |
| **60 days** | Implement | Close the scheme where leavers stay on the payroll: put in place leavers removed before next run. | HR or payroll manager | Leaver lists reconciled to payroll, the pay run checklist. | Management's own records show, for every case in the period: every leaver is confirmed as removed before the next pay run, using the HR leaver list. |
| **60 days** | Implement | Close the scheme where a false identity enters at hiring: put in place identity verified and qualifications verified. | HR or payroll manager | Verification service results on employee files, the onboarding checklist. Verification results from institutions or SAQA, the recruitment checklist. | Management's own records show, for every case in the period: every new employee's identity is verified against Home Affairs records, for example through a verification service, before they start. |
| **60 days** | Implement | Close the scheme where a stand-in or deepfake candidate is appointed: put in place remote appointee identity confirmed. | HR or payroll manager | The remote hiring procedure, identity check results, records of in-person meetings. | Management's own records show, for every case in the period: every remote appointee is confirmed through an in-person meeting or an identity check designed to resist replayed and injected video before access and pay are set up, and failed checks are reviewed by a person. |
| **60 days** | Implement | Close the scheme where refunds are stolen: put in place refunds approved independently, returns received before credit, claim evidence checked for AI and refund patterns reviewed. | Commercial or finance manager | A sample of refunds and credit notes with approvals, system workflow settings. | Management's own records show, for every case in the period: every refund and credit note is approved by someone other than the person who processes it. |
| **60 days** | Implement | Close the scheme where customer details are changed to divert money or goods: put in place customer detail changes verified, defined onboarding, shared details flagged and business customers verified. | Commercial or finance manager | Change logs for customer records, verification notes, the list of people who can change details. | Management's own records show, for every case in the period: every change to refund accounts, addresses and contact numbers is verified with the customer through known details and made by someone outside sales. |
| **60 days** | Implement | Close the scheme where credit is obtained with fabricated documents: put in place application documents verified, statements sent from the system, limit and terms changes approved and credit approved independently. | Commercial or finance manager | Verification records for a sample of applications, the credit procedure. Credit approval records, the credit authority matrix, system access to change limits. | Management's own records show, for every case in the period: the key information in every application is verified with the source, such as the employer, the bank or a verification service, before credit is approved. |
| **60 days** | Implement | Close the scheme where claims are fabricated or inflated: put in place fraud indicators screened. | Commercial or finance manager | The claims fraud indicator list, screening results, referrals to investigators. | Management's own records show, for every case in the period: every claim is screened against defined indicators, such as early claims, repeat claimants and recurring service providers, and flagged claims are referred. |
| **60 days** | Implement | Close the scheme where cash takings are stolen: put in place daily reconciliation. | Operations or financial manager | Daily reconciliation sheets, the shortages and surpluses log, investigation notes. | Management's own records show, for every case in the period: takings at every cash point are reconciled to sales records daily, and every shortage and surplus is investigated. |

| | | | | | |
|---|---|---|---|---|---|
| **60 days** | Implement | Close the scheme where stock is stolen and hidden in the counts: put in place independent blind counts, how stock is recorded, differences explained before adjusting and write-offs approved and supervised. | Operations or financial manager | Count instructions, count sheets without system quantities, the names of counters and observers. Approved write-off forms, disposal or destruction certificates, the write-off register. | Management's own records show, for every case in the period: every count is carried out or observed by people independent of the stores team, counting without sight of system quantities. |
| **60 days** | Implement | Close the scheme where a cloned voice or video instruction is obeyed: put in place verification for calls, voice notes and video, changes to call-back details verified and executives and their teams prepared. | Head of IT or IT provider | The verification procedure, briefing records for executives, simulation results. Change records for supplier and executive contact details, how each change was confirmed. Briefing records for executives, the agreed verification method, assistants' instructions. | Management's own records show, for every case in the period: an agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it. |
| **60 days** | Implement | Close the scheme where customer accounts are taken over: put in place customer logins protected. | Head of IT or IT provider | Customer authentication settings, lockout rules, takeover statistics. | Management's own records show, for every case in the period: customer logins are protected with multi-factor authentication, device recognition and limits on repeated failed attempts. |
| **60 days** | Implement | Close the scheme where a security compromise is not notified: put in place compromises reported as POPIA requires and affected people warned. | Head of IT or IT provider | The breach response procedure, notification templates, records of past notifications. | Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly. |
| **90 days** | Implement | Confirm with HR lead or ethics officer how code accessible to staff operates and put in place training on joining. | Ethics officer or company secretary | HR lead or ethics officer confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join? |
| **90 days** | Implement | Close the scheme where donations or sponsorships channel bribes: put in place recipients checked for links. | Ethics officer or company secretary | CSI or sustainability lead confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed? |
| **90 days** | Implement | Close the scheme where supplier payments are released without two approvals: put in place two approvers on banking platform. | Head of procurement or CFO | Banking platform user and approval settings, a sample of payment approvals. | Management's own records show, for every case in the period: the banking platform requires two separate people to approve every supplier payment. |
| **90 days** | Implement | Close the scheme where a tender is manipulated or purchases are split: put in place evaluation against set criteria and quote and tender thresholds. | Head of procurement or CFO | Evaluation scoresheets, the request for quotation or tender with its criteria, committee minutes. | Management's own records show, for every case in the period: every competitive purchase is evaluated by more than one person against criteria set before bids are received, and scores are recorded. |
| **90 days** | Implement | Close the scheme where buyers take kickbacks: put in place annual interest declarations. | Head of procurement or CFO | The declarations register for buying staff, completion records, follow-up of missing declarations. | Management's own records show, for every case in the period: everyone involved in buying declares interests each year and when circumstances change, and declarations are kept on record. |
| **90 days** | Implement | Close the scheme where purchase cards or petty cash are misused: put in place independent reconciliation. | Head of procurement or CFO | Financial controller confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Are statements reconciled and reviewed by someone other than the cardholder? |

| | | | | | |
|---|---|---|---|---|---|
| **90 days** | Implement | Close the scheme where intermediaries pay bribes or inflate fees: put in place intermediaries vetted. | Head of procurement or CFO | Head of procurement, with the business owner of each relationship confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Are intermediaries vetted before appointment, including who owns them and their reputation? |
| **90 days** | Implement | Close the scheme where procurement anomalies are never noticed: put in place senior review of supplier payments, data reviewed for unusual patterns, split orders monitored and independent review of procurement. | Head of procurement or CFO | Creditors manager or financial controller confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Does someone senior review a list of supplier payments at least once a month? |
| **90 days** | Implement | Close the scheme where variations inflate the agreed value: put in place variations approved first, contract register, large variations escalated and written supplier contracts. | Head of procurement or CFO | Procurement or the finance manager confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Must changes to agreed work, such as variations, extensions or extra scope, be approved before the work goes ahead, whether or not there is a written contract? |
| **90 days** | Implement | Close the scheme where the payroll payment file is altered after approval: put in place payment file protected. | HR or payroll manager | Payroll manager or financial controller confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Is the payroll payment file protected so that a change between approval and upload to the bank would be prevented or detected, for example through a secure bank connection or a file check that the preparer cannot regenerate? |
| **90 days** | Implement | Close the scheme where cash wages are stolen or paid to ghosts: put in place two people pay out cash. | HR or payroll manager | Financial controller confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Are cash wages paid out by at least two people together? |
| **90 days** | Implement | Close the scheme where hours and overtime are inflated: put in place hours approved by supervisor. | HR or payroll manager | HR or payroll manager confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Are hours approved by a supervisor before they are paid? |
| **90 days** | Implement | Close the scheme where expenses and advances are abused: put in place claims approved by a manager. | HR or payroll manager | Financial controller confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Is each claim approved by a manager other than the claimant? |
| **90 days** | Implement | Close the scheme where labour brokers invoice for workers who were not there: put in place broker invoices against attendance. | HR or payroll manager | Operations manager confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Are labour broker invoices checked against your own attendance records? |
| **90 days** | Implement | Close the scheme where an insider in a high-risk role works unchecked: put in place block leave required, concerns raised fairly, support for financial pressure and no conflicting duties when covering. | HR or payroll manager | The leave policy, leave records for sensitive roles, approved exceptions. The list of high-risk roles and the date it was last reviewed. | Management's own records show, for every case in the period: everyone in a sensitive role takes a block of consecutive leave each year, with their work done by someone else, and exceptions are approved. |
| **90 days** | Implement | Close the scheme where sales are not billed or receipts are diverted: put in place everything supplied is billed. | Commercial or finance manager | Delivery-to-invoice matching reports, investigation of unbilled items. | Management's own records show, for every case in the period: every delivery or service is matched to an invoice, and unbilled items are investigated. |

| | | | | | |
|---|---|---|---|---|---|
| **90 days** | Implement | Close the scheme where customers pay fraudsters impersonating the organisation: put in place customers warned about payment redirection. | Commercial or finance manager | Invoice and statement templates, customer communications on payment safety. | Management's own records show, for every case in the period: every invoice and statement shows the bank account and states that it will never change by email or message alone. |
| **90 days** | Implement | Close the scheme where prices are overridden or side deals made: put in place non-standard prices approved. | Commercial or finance manager | Sales or commercial manager confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Are prices or discounts outside the standard approved by someone other than the salesperson, within set limits? |
| **90 days** | Implement | Close the scheme where agents report fictitious sales: put in place agent sales verified. | Commercial or finance manager | Channel or sales manager confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Are sales reported by agents or resellers checked against real customer activity, such as payments received or goods delivered, before commission is paid? |
| **90 days** | Implement | Close the scheme where vouchers and loyalty points are abused: put in place vouchers controlled in the system. | Commercial or finance manager | Marketing manager confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Are vouchers, gift cards and promotion codes issued and redeemed through a system that prevents duplicates and records who issued them? |
| **90 days** | Implement | Close the scheme where customers are wrongly blocked on a fraud flag: put in place human review before a customer is blocked. | Commercial or finance manager | Fraud or risk lead confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Before a customer's account is blocked or a claim is declined because of a fraud flag, does a person review the decision? |
| **90 days** | Implement | Close the scheme where data leaves on disposed or reissued devices: put in place devices wiped before disposal. | Operations or financial manager | Asset or facilities manager confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Are laptops, phones and other devices wiped of the organisation's data before they are disposed of, sold, reissued or returned? |
| **90 days** | Implement | Close the scheme where assets or scrap are sold off cheaply or without payment: put in place paid before collection. | Operations or financial manager | Release records showing payment confirmed on the bank statement. | Management's own records show, for every case in the period: payment is confirmed on the organisation's own bank statement before any goods are collected. |
| **90 days** | Implement | Close the scheme where goods are released to an impostor: put in place changed collection instructions verified. | Operations or financial manager | Warehouse or stores manager confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: When an instruction to release or collect goods changes, such as a new delivery address or a different collector, is the change verified through known contact details, and is the collector's identity checked at release? |
| **90 days** | Implement | Close the scheme where fuel and fleet are misused: put in place fuel matched to distance. | Operations or financial manager | Fuel exception reports, tracking data comparisons, follow-up notes. | Management's own records show, for every case in the period: every vehicle's fuel purchases are compared with tracking data, distance travelled and expected consumption, and exceptions are investigated. |

| | | | | | |
|---|---|---|---|---|---|
| **90 days** | Implement | Close the scheme where goods go missing in transit: put in place dispatch matched to orders. | Operations or financial manager | Logistics manager confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Is every dispatch matched to an approved order before the goods leave? |
| **90 days** | Implement | Close the scheme where high-value materials are stolen by organised groups: put in place organised theft assessed. | Operations or financial manager | Security manager confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Is the risk of organised theft, such as theft of copper, cable, metals or fuel, assessed together with the security provider? |
| **90 days** | Implement | Close the scheme where losses are never tracked: put in place losses tracked and reported. | Operations or financial manager | Financial controller or internal audit confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Are losses of cash, stock and assets tracked over time and by location, and reported to management? |
| **90 days** | Implement | Close the scheme where a help desk reset hands an attacker access: put in place help desk resets verified. | Head of IT or IT provider | The help desk reset procedure, reset logs, social engineering test results. | Management's own records show, for every case in the period: every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel. |
| **90 days** | Implement | Close the scheme where systems that move money are accessed without strong sign-in: put in place multi-factor on critical systems. | Head of IT or IT provider | Multi-factor coverage reports for remote access, cloud and banking systems. | Management's own records show, for every case in the period: it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data. |
| **90 days** | Implement | Close the scheme where personal information is over-exposed or kept too long: put in place access to personal information limited. | Head of IT or IT provider | Role-based access settings, export restrictions, access reviews. | Management's own records show, for every case in the period: in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged. |
| **90 days** | Implement | Close the scheme where a SIM swap defeats one-time PIN approvals: put in place approval numbers protected. | Head of IT or IT provider | The list of numbers used for approvals, SIM-swap protection confirmations, authenticator app rollout. | Management's own records show, for every case in the period: every number used to approve payments or reset access has a network SIM-swap lock or has been replaced by an authenticator app. |
| **90 days** | Implement | Close the scheme where an AI assistant is manipulated by hidden instructions: put in place assistant permissions limited. | Head of IT or IT provider | Head of IT or the person responsible for AI tools confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Are the permissions of AI assistants limited to what each task needs, so that they cannot make payments, change records or send messages without a person's approval? |
| **90 days** | Implement | Close the scheme where the organisation's own information helps attackers: put in place staff guided on what not to share. | Head of IT or IT provider | Communications or marketing manager confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling? |

| | | | | | |
|---|---|---|---|---|---|
| **90 days** | Implement | Close the scheme where the organisation is impersonated to defraud others: put in place brand impersonation monitored and removed. | Head of IT or IT provider | CFO and head of IT together confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Does the organisation watch for fake websites, social media accounts and adverts that impersonate it, and have them taken down? |
| **90 days** | Implement | Close the scheme where spoofed email in the organisation's name deceives staff, suppliers or customers: put in place domain protected against spoofing. | Head of IT or IT provider | Head of IT or IT provider confirms in writing that the controls operate for every case. | Management's own records show that every case in the period passes this test: Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject? |
| **90 days** | Implement | Close the scheme where a compromise is not contained quickly: put in place compromise playbook. | Head of IT or IT provider | The incident plan for email compromise, its contact list, test or incident records. | Management's own records show, for every case in the period: a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Ethics officer or company secretary | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Ethics officer or company secretary | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Head of procurement or CFO | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: the duties are always separated, or any exception is approved and recorded. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Head of procurement or CFO | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: every provider's access is limited to what the service needs, logged and reviewed at least once a year. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Head of procurement or CFO | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: every competitive purchase is evaluated by more than one person against criteria set before bids are received, and scores are recorded. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Head of procurement or CFO | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: everyone involved in buying declares interests each year and when circumstances change, and declarations are kept on record. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Head of procurement or CFO | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Are statements reconciled and reviewed by someone other than the cardholder? |

| | | | | | |
|---|---|---|---|---|---|
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Head of procurement or CFO | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Are intermediaries vetted before appointment, including who owns them and their reputation? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Head of procurement or CFO | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Must changes to agreed work, such as variations, extensions or extra scope, be approved before the work goes ahead, whether or not there is a written contract? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | HR or payroll manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | HR or payroll manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Are hours approved by a supervisor before they are paid? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | HR or payroll manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Is each claim approved by a manager other than the claimant? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | HR or payroll manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Are labour broker invoices checked against your own attendance records? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | HR or payroll manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: everyone in a sensitive role takes a block of consecutive leave each year, with their work done by someone else, and exceptions are approved. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Commercial or finance manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: every refund and credit note is approved by someone other than the person who processes it. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Commercial or finance manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: the key information in every application is verified with the source, such as the employer, the bank or a verification service, before credit is approved. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Commercial or finance manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: every claim is screened against defined indicators, such as early claims, repeat claimants and recurring service providers, and flagged claims are referred. |

| | | | | | |
|---|---|---|---|---|---|
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Commercial or finance manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: every delivery or service is matched to an invoice, and unbilled items are investigated. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Commercial or finance manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: every invoice and statement shows the bank account and states that it will never change by email or message alone. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Commercial or finance manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Are prices or discounts outside the standard approved by someone other than the salesperson, within set limits? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Commercial or finance manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Are sales reported by agents or resellers checked against real customer activity, such as payments received or goods delivered, before commission is paid? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Commercial or finance manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Are vouchers, gift cards and promotion codes issued and redeemed through a system that prevents duplicates and records who issued them? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (Monthly), with a management sample and any exceptions recorded. | Commercial or finance manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Before a customer's account is blocked or a claim is declined because of a fraud flag, does a person review the decision? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Operations or financial manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Are laptops, phones and other devices wiped of the organisation's data before they are disposed of, sold, reissued or returned? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Operations or financial manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: payment is confirmed on the organisation's own bank statement before any goods are collected. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Operations or financial manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: every vehicle's fuel purchases are compared with tracking data, distance travelled and expected consumption, and exceptions are investigated. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Operations or financial manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Is every dispatch matched to an approved order before the goods leave? |

| | | | | | |
|---|---|---|---|---|---|
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Operations or financial manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Is the risk of organised theft, such as theft of copper, cable, metals or fuel, assessed together with the security provider? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (Monthly), with a management sample and any exceptions recorded. | Operations or financial manager | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Are losses of cash, stock and assets tracked over time and by location, and reported to management? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (Continuous, with monthly review), with a management sample and any exceptions recorded. | Head of IT or IT provider | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (Continuous, with monthly review), with a management sample and any exceptions recorded. | Head of IT or IT provider | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Head of IT or IT provider | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: customer logins are protected with multi-factor authentication, device recognition and limits on repeated failed attempts. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Head of IT or IT provider | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (Every joiner, mover and leaver, and quarterly review), with a management sample and any exceptions recorded. | Head of IT or IT provider | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (Every joiner, mover and leaver, and quarterly review), with a management sample and any exceptions recorded. | Head of IT or IT provider | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Head of IT or IT provider | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged. |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Head of IT or IT provider | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: every number used to approve payments or reset access has a network SIM-swap lock or has been replaced by an authenticator app. |

| | | | | | |
|---|---|---|---|---|---|
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Head of IT or IT provider | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Are the permissions of AI assistants limited to what each task needs, so that they cannot make payments, change records or send messages without a person's approval? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Head of IT or IT provider | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (Continuous, with monthly review), with a management sample and any exceptions recorded. | Head of IT or IT provider | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show that every case in the period passes this test: Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject? |
| **3-6 months** | Embed & evidence | Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded. | Head of IT or IT provider | The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated. | Management's own records show, for every case in the period: a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D3-10 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join? | Ethics officer or company secretary | Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join? | Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D3-11 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed? | Ethics officer or company secretary | Management's own records show that every case in the period passes this test: Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed? | Management's own records show that every case in the period passes this test: Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D4-04 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: the duties are always separated, or any exception is approved and recorded. | Head of procurement or CFO | Management's own records show, for every case in the period: the duties are always separated, or any exception is approved and recorded. | Management's own records show, for every case in the period: the duties are always separated, or any exception is approved and recorded. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D4-06 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: every provider's access is limited to what the service needs, logged and reviewed at least once a year. | Head of procurement or CFO | Management's own records show, for every case in the period: every provider's access is limited to what the service needs, logged and reviewed at least once a year. | Management's own records show, for every case in the period: every provider's access is limited to what the service needs, logged and reviewed at least once a year. |

| | | | | | |
|---|---|---|---|---|---|
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D4-08 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: every competitive purchase is evaluated by more than one person against criteria set before bids are received, and scores are recorded. | Head of procurement or CFO | Management's own records show, for every case in the period: every competitive purchase is evaluated by more than one person against criteria set before bids are received, and scores are recorded. | Management's own records show, for every case in the period: every competitive purchase is evaluated by more than one person against criteria set before bids are received, and scores are recorded. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D4-09 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: everyone involved in buying declares interests each year and when circumstances change, and declarations are kept on record. | Head of procurement or CFO | Management's own records show, for every case in the period: everyone involved in buying declares interests each year and when circumstances change, and declarations are kept on record. | Management's own records show, for every case in the period: everyone involved in buying declares interests each year and when circumstances change, and declarations are kept on record. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D4-10 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are statements reconciled and reviewed by someone other than the cardholder? | Head of procurement or CFO | Management's own records show that every case in the period passes this test: Are statements reconciled and reviewed by someone other than the cardholder? | Management's own records show that every case in the period passes this test: Are statements reconciled and reviewed by someone other than the cardholder? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D4-11 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are intermediaries vetted before appointment, including who owns them and their reputation? | Head of procurement or CFO | Management's own records show that every case in the period passes this test: Are intermediaries vetted before appointment, including who owns them and their reputation? | Management's own records show that every case in the period passes this test: Are intermediaries vetted before appointment, including who owns them and their reputation? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D4-13 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Must changes to agreed work, such as variations, extensions or extra scope, be approved before the work goes ahead, whether or not there is a written contract? | Head of procurement or CFO | Management's own records show that every case in the period passes this test: Must changes to agreed work, such as variations, extensions or extra scope, be approved before the work goes ahead, whether or not there is a written contract? | Management's own records show that every case in the period passes this test: Must changes to agreed work, such as variations, extensions or extra scope, be approved before the work goes ahead, whether or not there is a written contract? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D5-01 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect. | HR or payroll manager | Management's own records show, for every case in the period: every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect. | Management's own records show, for every case in the period: every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D5-09 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are hours approved by a supervisor before they are paid? | HR or payroll manager | Management's own records show that every case in the period passes this test: Are hours approved by a supervisor before they are paid? | Management's own records show that every case in the period passes this test: Are hours approved by a supervisor before they are paid? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D5-10 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Is each claim approved by a manager other than the claimant? | HR or payroll manager | Management's own records show that every case in the period passes this test: Is each claim approved by a manager other than the claimant? | Management's own records show that every case in the period passes this test: Is each claim approved by a manager other than the claimant? |

| | | | | | |
|---|---|---|---|---|---|
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D5-11 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are labour broker invoices checked against your own attendance records? | HR or payroll manager | Management's own records show that every case in the period passes this test: Are labour broker invoices checked against your own attendance records? | Management's own records show that every case in the period passes this test: Are labour broker invoices checked against your own attendance records? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D5-12 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: everyone in a sensitive role takes a block of consecutive leave each year, with their work done by someone else, and exceptions are approved. | HR or payroll manager | Management's own records show, for every case in the period: everyone in a sensitive role takes a block of consecutive leave each year, with their work done by someone else, and exceptions are approved. | Management's own records show, for every case in the period: everyone in a sensitive role takes a block of consecutive leave each year, with their work done by someone else, and exceptions are approved. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D7-01 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: every refund and credit note is approved by someone other than the person who processes it. | Commercial or finance manager | Management's own records show, for every case in the period: every refund and credit note is approved by someone other than the person who processes it. | Management's own records show, for every case in the period: every refund and credit note is approved by someone other than the person who processes it. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D7-03 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: the key information in every application is verified with the source, such as the employer, the bank or a verification service, before credit is approved. | Commercial or finance manager | Management's own records show, for every case in the period: the key information in every application is verified with the source, such as the employer, the bank or a verification service, before credit is approved. | Management's own records show, for every case in the period: the key information in every application is verified with the source, such as the employer, the bank or a verification service, before credit is approved. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D7-05 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: every claim is screened against defined indicators, such as early claims, repeat claimants and recurring service providers, and flagged claims are referred. | Commercial or finance manager | Management's own records show, for every case in the period: every claim is screened against defined indicators, such as early claims, repeat claimants and recurring service providers, and flagged claims are referred. | Management's own records show, for every case in the period: every claim is screened against defined indicators, such as early claims, repeat claimants and recurring service providers, and flagged claims are referred. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D7-09 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: every delivery or service is matched to an invoice, and unbilled items are investigated. | Commercial or finance manager | Management's own records show, for every case in the period: every delivery or service is matched to an invoice, and unbilled items are investigated. | Management's own records show, for every case in the period: every delivery or service is matched to an invoice, and unbilled items are investigated. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D7-10 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: every invoice and statement shows the bank account and states that it will never change by email or message alone. | Commercial or finance manager | Management's own records show, for every case in the period: every invoice and statement shows the bank account and states that it will never change by email or message alone. | Management's own records show, for every case in the period: every invoice and statement shows the bank account and states that it will never change by email or message alone. |

| | | | | | |
|---|---|---|---|---|---|
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D7-11 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are prices or discounts outside the standard approved by someone other than the salesperson, within set limits? | Commercial or finance manager | Management's own records show that every case in the period passes this test: Are prices or discounts outside the standard approved by someone other than the salesperson, within set limits? | Management's own records show that every case in the period passes this test: Are prices or discounts outside the standard approved by someone other than the salesperson, within set limits? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D7-12 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are sales reported by agents or resellers checked against real customer activity, such as payments received or goods delivered, before commission is paid? | Commercial or finance manager | Management's own records show that every case in the period passes this test: Are sales reported by agents or resellers checked against real customer activity, such as payments received or goods delivered, before commission is paid? | Management's own records show that every case in the period passes this test: Are sales reported by agents or resellers checked against real customer activity, such as payments received or goods delivered, before commission is paid? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D7-13 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are vouchers, gift cards and promotion codes issued and redeemed through a system that prevents duplicates and records who issued them? | Commercial or finance manager | Management's own records show that every case in the period passes this test: Are vouchers, gift cards and promotion codes issued and redeemed through a system that prevents duplicates and records who issued them? | Management's own records show that every case in the period passes this test: Are vouchers, gift cards and promotion codes issued and redeemed through a system that prevents duplicates and records who issued them? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D7-14 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Before a customer's account is blocked or a claim is declined because of a fraud flag, does a person review the decision? | Commercial or finance manager | Management's own records show that every case in the period passes this test: Before a customer's account is blocked or a claim is declined because of a fraud flag, does a person review the decision? | Management's own records show that every case in the period passes this test: Before a customer's account is blocked or a claim is declined because of a fraud flag, does a person review the decision? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D8-04 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are laptops, phones and other devices wiped of the organisation's data before they are disposed of, sold, reissued or returned? | Operations or financial manager | Management's own records show that every case in the period passes this test: Are laptops, phones and other devices wiped of the organisation's data before they are disposed of, sold, reissued or returned? | Management's own records show that every case in the period passes this test: Are laptops, phones and other devices wiped of the organisation's data before they are disposed of, sold, reissued or returned? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D8-05 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: payment is confirmed on the organisation's own bank statement before any goods are collected. | Operations or financial manager | Management's own records show, for every case in the period: payment is confirmed on the organisation's own bank statement before any goods are collected. | Management's own records show, for every case in the period: payment is confirmed on the organisation's own bank statement before any goods are collected. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D8-07 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: every vehicle's fuel purchases are compared with tracking data, distance travelled and expected consumption, and exceptions are investigated. | Operations or financial manager | Management's own records show, for every case in the period: every vehicle's fuel purchases are compared with tracking data, distance travelled and expected consumption, and exceptions are investigated. | Management's own records show, for every case in the period: every vehicle's fuel purchases are compared with tracking data, distance travelled and expected consumption, and exceptions are investigated. |

| | | | | | |
|---|---|---|---|---|---|
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D8-08 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Is every dispatch matched to an approved order before the goods leave? | Operations or financial manager | Management's own records show that every case in the period passes this test: Is every dispatch matched to an approved order before the goods leave? | Management's own records show that every case in the period passes this test: Is every dispatch matched to an approved order before the goods leave? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D8-09 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Is the risk of organised theft, such as theft of copper, cable, metals or fuel, assessed together with the security provider? | Operations or financial manager | Management's own records show that every case in the period passes this test: Is the risk of organised theft, such as theft of copper, cable, metals or fuel, assessed together with the security provider? | Management's own records show that every case in the period passes this test: Is the risk of organised theft, such as theft of copper, cable, metals or fuel, assessed together with the security provider? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D8-11 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are losses of cash, stock and assets tracked over time and by location, and reported to management? | Operations or financial manager | Management's own records show that every case in the period passes this test: Are losses of cash, stock and assets tracked over time and by location, and reported to management? | Management's own records show that every case in the period passes this test: Are losses of cash, stock and assets tracked over time and by location, and reported to management? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D9-01 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. | Head of IT or IT provider | Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. | Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D9-02 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it. | Head of IT or IT provider | Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it. | Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D9-04 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: customer logins are protected with multi-factor authentication, device recognition and limits on repeated failed attempts. | Head of IT or IT provider | Management's own records show, for every case in the period: customer logins are protected with multi-factor authentication, device recognition and limits on repeated failed attempts. | Management's own records show, for every case in the period: customer logins are protected with multi-factor authentication, device recognition and limits on repeated failed attempts. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D9-05 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly. | Head of IT or IT provider | Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly. | Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly. |

| | | | | | |
|---|---|---|---|---|---|
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D9-06 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel. | Head of IT or IT provider | Management's own records show, for every case in the period: every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel. | Management's own records show, for every case in the period: every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D9-07 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data. | Head of IT or IT provider | Management's own records show, for every case in the period: it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data. | Management's own records show, for every case in the period: it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D9-08 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged. | Head of IT or IT provider | Management's own records show, for every case in the period: in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged. | Management's own records show, for every case in the period: in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D9-09 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: every number used to approve payments or reset access has a network SIM-swap lock or has been replaced by an authenticator app. | Head of IT or IT provider | Management's own records show, for every case in the period: every number used to approve payments or reset access has a network SIM-swap lock or has been replaced by an authenticator app. | Management's own records show, for every case in the period: every number used to approve payments or reset access has a network SIM-swap lock or has been replaced by an authenticator app. |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D9-10 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are the permissions of AI assistants limited to what each task needs, so that they cannot make payments, change records or send messages without a person's approval? | Head of IT or IT provider | Management's own records show that every case in the period passes this test: Are the permissions of AI assistants limited to what each task needs, so that they cannot make payments, change records or send messages without a person's approval? | Management's own records show that every case in the period passes this test: Are the permissions of AI assistants limited to what each task needs, so that they cannot make payments, change records or send messages without a person's approval? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D9-11 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling? | Head of IT or IT provider | Management's own records show that every case in the period passes this test: Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling? | Management's own records show that every case in the period passes this test: Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling? |
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D9-14 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject? | Head of IT or IT provider | Management's own records show that every case in the period passes this test: Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject? | Management's own records show that every case in the period passes this test: Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject? |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

| | | | | | |
|---|---|---|---|---|---|
| **6-12 months** | Assure & review | A management or assurance review of CI-FS-D9-12 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles. | Head of IT or IT provider | Management's own records show, for every case in the period: a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles. | Management's own records show, for every case in the period: a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles. |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

# Measurement register

The effectiveness test behind each recommended control, grouped by programme. These are the signals management should expect once the control operates.

## Supplier and payment integrity

| MEASURE | CONTROLS IT COVERS |
|---|---|
| Management's own records show that every case in the period passes this test: Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed? | CI-FS-D3-11 |
| Management's own records show, for every case in the period: every new supplier goes through a defined process, with set checks and an approval, before it can be paid. | CI-FS-D4-01 |
| Management's own records show, for every case in the period: the procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why. | CI-FS-D4-02 |
| Management's own records show, for every case in the period: every new supplier's account is verified through a bank or third-party service before the first payment. | CI-FS-D4-03 |
| Management's own records show, for every case in the period: the duties are always separated, or any exception is approved and recorded. | CI-FS-D4-04 |
| Management's own records show, for every case in the period: every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first. | CI-FS-D4-05 |
| Management's own records show, for every case in the period: every provider's access is limited to what the service needs, logged and reviewed at least once a year. | CI-FS-D4-06 |
| Management's own records show, for every case in the period: the banking platform requires two separate people to approve every supplier payment. | CI-FS-D4-07 |
| Management's own records show, for every case in the period: every competitive purchase is evaluated by more than one person against criteria set before bids are received, and scores are recorded. | CI-FS-D4-08 |
| Management's own records show, for every case in the period: everyone involved in buying declares interests each year and when circumstances change, and declarations are kept on record. | CI-FS-D4-09 |
| Management's own records show that every case in the period passes this test: Are statements reconciled and reviewed by someone other than the cardholder? | CI-FS-D4-10 |
| Management's own records show that every case in the period passes this test: Are intermediaries vetted before appointment, including who owns them and their reputation? | CI-FS-D4-11 |
| Management's own records show that every case in the period passes this test: Does someone senior review a list of supplier payments at least once a month? | CI-FS-D4-12 |
| Management's own records show that every case in the period passes this test: Must changes to agreed work, such as variations, extensions or extra scope, be approved before the work goes ahead, whether or not there is a written contract? | CI-FS-D4-13 |
| Management's own records show that every case in the period passes this test: Are sales reported by agents or resellers checked against real customer activity, such as payments received or goods delivered, before commission is paid? | CI-FS-D7-12 |

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

| MEASURE | CONTROLS IT COVERS |
|---|---|
| Management's own records show, for every case in the period: everyone in a sensitive role takes a block of consecutive leave each year, with their work done by someone else, and exceptions are approved. | CI-FS-D5-12 |
| Management's own records show, for every case in the period: every change to refund accounts, addresses and contact numbers is verified with the customer through known details and made by someone outside sales. | CI-FS-D7-02 |
| Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. | CI-FS-D9-01 |
| Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it. | CI-FS-D9-02 |
| Management's own records show, for every case in the period: an agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it. | CI-FS-D9-03 |
| Management's own records show, for every case in the period: customer logins are protected with multi-factor authentication, device recognition and limits on repeated failed attempts. | CI-FS-D9-04 |
| Management's own records show, for every case in the period: every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel. | CI-FS-D9-06 |
| Management's own records show, for every case in the period: it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data. | CI-FS-D9-07 |
| Management's own records show, for every case in the period: in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged. | CI-FS-D9-08 |
| Management's own records show, for every case in the period: every number used to approve payments or reset access has a network SIM-swap lock or has been replaced by an authenticator app. | CI-FS-D9-09 |
| Management's own records show that every case in the period passes this test: Are the permissions of AI assistants limited to what each task needs, so that they cannot make payments, change records or send messages without a person's approval? | CI-FS-D9-10 |
| Management's own records show that every case in the period passes this test: Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling? | CI-FS-D9-11 |
| Management's own records show that every case in the period passes this test: Does the organisation watch for fake websites, social media accounts and adverts that impersonate it, and have them taken down? | CI-FS-D9-13 |
| Management's own records show that every case in the period passes this test: Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject? | CI-FS-D9-14 |

## Payroll integrity

| MEASURE | CONTROLS IT COVERS |
|---|---|
| Management's own records show, for every case in the period: every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect. | CI-FS-D5-01 |
| Management's own records show, for every case in the period: every payroll run is reviewed before payment by someone who did not prepare it, and the review is recorded. | CI-FS-D5-02 |
| Management's own records show, for every case in the period: every leaver is confirmed as removed before the next pay run, using the HR leaver list. | CI-FS-D5-03 |
| Management's own records show, for every case in the period: every new employee's identity is verified against Home Affairs records, for example through a verification service, before they start. | CI-FS-D5-04 |
| Management's own records show, for every case in the period: every remote appointee is confirmed through an in-person meeting or an identity check designed to resist replayed and injected video before access and pay are set up, and failed checks are reviewed by a person. | CI-FS-D5-05 |
| Management's own records show that every case in the period passes this test: Is the payroll payment file protected so that a change between approval and upload to the bank would be prevented or detected, for example through a secure bank connection or a file check that the preparer cannot regenerate? | CI-FS-D5-07 |
| Management's own records show that every case in the period passes this test: Are cash wages paid out by at least two people together? | CI-FS-D5-08 |
| Management's own records show that every case in the period passes this test: Are hours approved by a supervisor before they are paid? | CI-FS-D5-09 |
| Management's own records show that every case in the period passes this test: Is each claim approved by a manager other than the claimant? | CI-FS-D5-10 |
| Management's own records show that every case in the period passes this test: Are labour broker invoices checked against your own attendance records? | CI-FS-D5-11 |

| MEASURE | CONTROLS IT COVERS |
|---|---|
| Management's own records show, for every case in the period: every refund and credit note is approved by someone other than the person who processes it. | CI-FS-D7-01 |
| Management's own records show, for every case in the period: the key information in every application is verified with the source, such as the employer, the bank or a verification service, before credit is approved. | CI-FS-D7-03 |
| Management's own records show, for every case in the period: every claim is screened against defined indicators, such as early claims, repeat claimants and recurring service providers, and flagged claims are referred. | CI-FS-D7-05 |
| Management's own records show, for every case in the period: every delivery or service is matched to an invoice, and unbilled items are investigated. | CI-FS-D7-09 |
| Management's own records show, for every case in the period: every invoice and statement shows the bank account and states that it will never change by email or message alone. | CI-FS-D7-10 |
| Management's own records show that every case in the period passes this test: Are prices or discounts outside the standard approved by someone other than the salesperson, within set limits? | CI-FS-D7-11 |
| Management's own records show that every case in the period passes this test: Are vouchers, gift cards and promotion codes issued and redeemed through a system that prevents duplicates and records who issued them? | CI-FS-D7-13 |
| Management's own records show that every case in the period passes this test: Before a customer's account is blocked or a claim is declined because of a fraud flag, does a person review the decision? | CI-FS-D7-14 |

## Stock and asset custody

| MEASURE | CONTROLS IT COVERS |
|---|---|
| Management's own records show, for every case in the period: every count is carried out or observed by people independent of the stores team, counting without sight of system quantities. | CI-FS-D8-02 |
| Management's own records show that every case in the period passes this test: Are laptops, phones and other devices wiped of the organisation's data before they are disposed of, sold, reissued or returned? | CI-FS-D8-04 |
| Management's own records show, for every case in the period: payment is confirmed on the organisation's own bank statement before any goods are collected. | CI-FS-D8-05 |
| Management's own records show that every case in the period passes this test: When an instruction to release or collect goods changes, such as a new delivery address or a different collector, is the change verified through known contact details, and is the collector's identity checked at release? | CI-FS-D8-06 |
| Management's own records show, for every case in the period: every vehicle's fuel purchases are compared with tracking data, distance travelled and expected consumption, and exceptions are investigated. | CI-FS-D8-07 |
| Management's own records show that every case in the period passes this test: Is every dispatch matched to an approved order before the goods leave? | CI-FS-D8-08 |
| Management's own records show that every case in the period passes this test: Is the risk of organised theft, such as theft of copper, cable, metals or fuel, assessed together with the security provider? | CI-FS-D8-09 |
| Management's own records show that every case in the period passes this test: Are losses of cash, stock and assets tracked over time and by location, and reported to management? | CI-FS-D8-11 |

## Incident response and evidence integrity

| MEASURE | CONTROLS IT COVERS |
|---|---|
| Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly. | CI-FS-D9-05 |
| Management's own records show, for every case in the period: a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles. | CI-FS-D9-12 |

## Culture and continuous improvement

| MEASURE | CONTROLS IT COVERS |
|---|---|
| Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join? | CI-FS-D3-10 |

## Cash custody

| MEASURE | CONTROLS IT COVERS |
|---|---|
| Management's own records show, for every case in the period: takings at every cash point are reconciled to sales records daily, and every shortage and surplus is investigated. | CI-FS-D8-01 |